



國立台灣科技大學
電 機 系
碩 士 學 位 論 文

學號：M11307513

結合大語言模型與資安領域預訓練模型應用於深度
學習之威脅偵測系統

A Deep Learning-Based Threat Detection System
Integrating Large Language Models and
Cybersecurity Domain-Specific Pre-trained Models

研 究 生：余 仲 恩

指導教授：黃意婷博士

中 華 民 國 一 一 五 年 七 月 三 十 日

中文摘要

隨著資訊技術的發展，進階持續性威脅 (Advanced Persistent Threats, APT) 已成為企業網路面臨的主要資安挑戰。APT 攻擊者常透過多階段滲透，並劫持多個節點作為跳板，長期潛伏於受害者環境中。近年來，基於系統審計日誌 (Audit Log) 建構溯源圖 (Provenance Graph) 並結合機器學習技術的入侵偵測系統，已成為偵測此類複雜攻擊的重要研究方向。

然而，現有系統仍面臨關鍵挑戰：首先是缺乏「語意理解」能力，現有機制大多僅能進行初步的異常行為辨識，無法直接指出該異常隸屬於 MITRE ATTCK 框架中的何種戰術 (Tactic) 與技術 (Technique)，導致資安人員後續仍需耗費大量人工進行數位鑑識；其次是難以有效區分合法應用程式的常規行為與具隱蔽性的惡意操作，導致部分攻擊行為容易成為漏網之魚。

為解決上述問題，本研究提出一個結合大型語言模型 (LLM) 與預訓練模型 SecureBERT 2.0 的威脅偵測架構。我們將審計日誌結合 LLM 生成具備上下文的自然語言敘述，並使用資安領域的預訓練模型 SecureBERT 2.0 萃取特徵向量 (Embeddings)，藉此大幅豐富原始日誌的語意。基於此方法，本研究的具體貢獻包含以下三個面向：第一，異常偵測 (Anomaly Detection)：利用豐富的語意特徵，有效過濾系統中的常規操作，精準識別出潛在的異常行為。第二，入侵偵測 (Intrusion Detection)：針對識別出的異常行為進行深度分析與分類，確認是否為真實的惡意攻擊，從而有效降低系統誤報率。第三，TTP 偵測 (TTP Detection)：將確認的入侵行為對應至 MITRE ATTCK 框架，精準辨別具體的攻擊手法與戰術。本研究預期能顯著提升系統對惡意行為的解釋能力與偵測精準度，為資安分析人員提供更高效率的防禦與鑑識方案。

ABSTRACT

With the development of information technology, Advanced Persistent Threats (APTs) have become a major cybersecurity challenge for enterprise networks. APT attackers often use multi-stage infiltration and hijack multiple nodes as pivot points, staying hidden in the victim's environment for a long time. In recent years, intrusion detection systems that build Provenance Graphs based on system audit logs and combine machine learning technologies have become an important research direction for detecting such complex attacks.

However, existing systems still face key challenges. The first is the lack of "semantic understanding." Most current mechanisms can only identify basic abnormal behaviors and cannot directly point out which Tactic and Technique in the MITRE ATTCK framework the anomaly belongs to. This forces security personnel to spend a lot of manual effort on digital forensics later. The second challenge is the difficulty in effectively distinguishing normal behaviors of legitimate applications from stealthy malicious operations, allowing some attacks to slip through the cracks.

To solve these problems, this research proposes a threat detection architecture combining Large Language Models (LLMs) and the pre-trained model SecureBERT 2.0. We combine audit logs with LLMs to generate context-aware natural language descriptions, and use the cybersecurity-specific pre-trained model SecureBERT 2.0 to extract feature vectors (embeddings). This method greatly enriches the semantic meaning of the raw logs. Based on this approach, the specific contributions of this study include the following three aspects: First, Anomaly Detection: Using the enriched semantic features to effectively filter out normal system operations and accurately identify potential abnormal behaviors. Second, Intrusion Detection: Conducting in-depth analysis on the identified anomalies to confirm whether they are real malicious attacks, thereby effectively reducing the false positive rate. Third, TTP Detection: Mapping the confirmed intrusions to the MITRE ATTCK framework to accurately identify the specific attack tactics and techniques. This research is expected to significantly improve the system's explainability of malicious behaviors and detection accuracy, providing security analysts with a more efficient defense and forensics solution.

誌 謝

感謝教授、各位學長姐和同學。



目 錄

論文摘要	I
Abstract	II
誌謝	III
目錄	IV
圖目錄	VII
表目錄	VIII
第一章 緒論	1
1.1 研究問題	2
1.2 研究目的	2
1.3 研究貢獻	3
1.3.1 提出基於語意增強的異常過濾機制	3
1.3.2 具備精準預測進階持續性威脅攻擊的能力	3
1.3.3 實現高準確度且低誤報率的入侵偵測與警報系統	3
第二章 文獻探討	4
2.1 溯源圖技術分析	4
2.2 異常偵測技術分析	5
2.2.1 基於專家規則的偵測方法	5

2.2.2	基於溯源圖結構的偵測方法	6
2.2.3	基於深度學習結構的偵測方法	7
2.3	攻擊偵測技術分析	8
2.4	資安日誌與指令嵌入模型之演進與分析	10
第三章	研究方法	13
3.1	前處理	13
3.1.1	溯源圖定義	13
3.1.2	溯源圖建構	14
3.2	系統架構總覽	16
3.3	日誌前處理與語意增強機制	17
3.3.1	結合 LLM 之自然語言敘述生成	17
3.3.2	基於 SecureBERT 2.0 的特徵萃取	19
3.3.3	異常偵測 (Anomaly Detection)	20
3.3.4	TTP 偵測 (TTP Detection)	22
3.3.5	入侵偵測 (Intrusion Detection)	25
第四章	實驗設計	28
4.1	訓練環境與參數設置	28
4.2	資料集	29
4.2.1	SAGA (Synthetic Audit Log Generation for APT Campaigns) 資料集	29
4.2.2	Kollect4APT 資料集	29
4.3	資料集切分方式	30
4.3.1	KELLECT4APT 切分	31

4.3.2 SAGA dataset 切分	31
4.4 異常偵測比較	32
4.5 TTP 偵測比較	32
第五章 實驗結果與分析	34
5.1 異常偵測結果與分析	34
5.2 TTP 偵測結果與分析	36
5.2.1 針對 KELLECT4APT 的分析	36
第六章 結論與後續工作	38
6.1 結論	38
6.2 後續工作與未來展望	39
參考文獻	40
授權書	44



圖 目 錄

圖 3.1 系統架構圖	27
-----------------------	----



表 目 錄

表 2-1	本研究與現有溯源圖偵測系統之能力比較	12
表 3-1	Relations extracted from ETW(Event Tracing for Windows)	15
表 3-2	Relations extracted from Procmon	15
表 4-1	Statistics of Datasets	30
表 5-1	Comparison of OneClassSVM (RBF) and OneClassSVM (Nystroem) .	34
表 5-2	TTP Detection Performance on KELLECT4APT	37
表 5-3	Evaluation Results of TTP Detection without LLM embedding	37
表 5-4	Evaluation Results of TTP detection with and w/o LLM embedding . .	37
表 5-5	Evaluation Results of TTP detection with different multi-chunk method	37

第一章 緒論

隨著資訊技術發展，進階持續性威脅 (Advanced Persistent Threat, APT) 已成為企業與組織面臨的主要資安挑戰。有別於傳統攻擊，APT 攻擊者通常會透過多階段的惡意行為進行滲透，並長期潛伏於受害網路中。在現代企業網路環境下，攻擊活動往往不侷限於單一節點，而是藉由劫持多部主機作為跳板 (Pivot)，或從初始入口點 (Entry Point) 逐步獲取橫向移動權限與關鍵節點的存取權限。

為偵測此類複雜且具隱蔽性的攻擊，基於溯源圖 (Provenance Graph) 的入侵偵測系統成為近年研究重點。此類系統主要利用系統審計日誌 (Audit Logs)，將 Process、File、Registry 與 Network Socket 等等建構為節點，並將系統操作行為視為邊，藉此描繪出實體間的因果關聯。結合機器學習或深度學習等演算法，溯源圖能有效捕捉系統行為的上下文，進而達到異常檢測的目的。

然而，對資安事件鑑識與應變而言，僅辨識行為的惡意與否並不足以了解全局的資安威脅情形，掌握確切的攻擊手法才能大幅提升威脅分析的效率。現有多數入侵偵測方法往往只能給出二元分類結果，缺乏具體的攻擊細節與語意解釋，導致後續資安剖析面臨困難。

針對上述限制，本研究旨在探討如何透過深度學習架構，精準偵測並辨別具體的攻擊戰術、技術與子技術 (TTPs)。本研究提出將審計日誌結合大型語言模型 (LLM) 生成具備上下文資訊的自然語言敘述，並使用具資安領域知識的預訓練模型 SecureBERT 2.0 [1] 萃取語意特徵。此方法不僅能豐富原始日誌的語意表示，更能有效連結系統底層行為與高階攻擊語意，從而實現入侵偵測及 TTP 辨別。

1.1 研究問題

現有的溯源圖偵測系統如 SLOT [2] 與 Kairos [3] 在偵測惡意行為的準確率上已有顯著成效，但仍存在以下關鍵問題：

1. **缺乏語意理解能力**：現有多數研究的核心機制僅停留在異常偵測 (Anomaly Detection)，系統僅能判斷該行為是否異常，卻無法直接指出該異常隸屬於 MITRE ATT&CK [4] 框架中的戰術 (Tactic) 與技術 (Technique)。對資安分析人員而言，這意味著後續仍需耗費大量人工查核與驗證，才能完整拼湊出攻擊者的攻擊路徑與具體手法。
2. **合法與惡意行為的區分挑戰**：現有方法在不依賴黑名單的情況下，難以有效區分正常應用程式的常規系統操作與具隱蔽性的惡意行為（例如將惡意操作偽裝成正常程序的讀寫或連線）。這導致系統容易產生誤報，或使部分行為潛伏的惡意行為成為漏網之魚。



1.2 研究目的

為了解決上述問題，本研究旨在提出一個結合大型語言模型 (LLM) 與預訓練模型 SecureBERT 2.0 的威脅偵測架構。透過將審計日誌 (Audit Log) 結合大型語言模型生成具備上下文資訊的自然語言敘述，並使用 SecureBERT 2.0 [1] 將自然語言轉換為特徵向量 (Embeddings)，以豐富日誌的語意表示。具體研究目標涵蓋以下三個層面：

1. **異常偵測 (Anomaly Detection)**：利用審計日誌裡的資訊透過資安領域預訓練模型產生的語意特徵使機器學習模型有效的學習系統日誌中常規與非常規的操作模式，進而在大量的系統日誌中精準識別出潛在的異常行為，初步過濾正常節點並且將異常行為節點的資訊串流到下一階段的 TTP 偵測模型。
2. **TTP 偵測 (TTP Detection)**：利用審計日誌裡的資訊透過大語言模型以及資安領域預訓練模型產生的語意特徵將確認為惡意的異常行為節點資訊與高階攻擊語意進行連結，精準對應至 MITRE ATT&CK 框架，辨別出具體的攻擊戰術與技術，賦予系統解釋攻擊行為的能力。
3. **入侵偵測 (Intrusion Detection)**：針對已識別出的異常行為進行深度的特徵分析與分類，確認其一連串惡意行為是否構成真實的惡意攻擊。透過此階段的過濾，確

保系統僅在面臨真實威脅時才觸發警報，有效降低誤報率 (False Positive Rate)。

1.3 研究貢獻

本研究透過應用大語言模型與預訓練模型結合機器學習及深度學習在系統審計日誌上判斷惡意及具體攻擊技術，具體貢獻如下：

1.3.1 提出基於語意增強的異常過濾機制

透過將系統審計日誌結合大語言模型轉換為自然語言敘述，並利用 SecureBERT 2.0 萃取自然語言敘述的特徵，本研究賦予系統深度的語意理解能力。此方法能透過深度學習架構學習系統常規操作模式，在海量日誌中識別出潛在的異常行為，達成初步的流量過濾。



1.3.2 具備精準預測進階持續性威脅攻擊的能力

針對識別出的潛在異常行為，並且進一步將其與高階攻擊語意進行連結，直接對應至 MITRE ATT&CK 框架。本系統不僅能發現異常，更能辨別出對應的攻擊戰術與技術，賦予系統解釋攻擊手法的能力，大幅減輕資安鑑識人員的分析負擔。

1.3.3 實現高準確度且低誤報率的入侵偵測與警報系統

在完成異常特徵提取與 TTP 語意映射後，本架構針對這些行為進行最終的深度分類與分析，以確認是否構成真實的惡意攻擊。這種漸進式的驗證過濾機制，確保了系統僅在面臨真實威脅時才觸發警報，為受害者提供具可信度的攻擊資訊，並有效降低整體的誤報率。

第二章 文獻探討

本章旨在探討與進階持續性威脅 (APT) 及入侵偵測相關技術文獻。首先介紹溯源圖 (Provenance Graph) 技術的基礎概念，探討審計日誌在紀錄與還原系統軌跡上之應用。接著將針對現有的異常偵測技術進行分類與比較，依序評估基於專家規則、溯源圖結構以及深度學習等不同架構之優劣與限制並且進一步聚焦於攻擊偵測技術之發展脈絡，探討如何從龐大的系統行為中精準識別惡行行為。最後將分析資安日誌與指令嵌入預訓練模型 (Embedding Models) 的演進，說明如何將底層系統日誌轉換為富含語意的特徵表示。藉由分析上述相關領域文獻，將為後續的系統架構設計與特徵萃取方法奠定堅實的理論基礎。



2.1 溯源圖技術分析

在深入探討各類偵測技術之前，首先需釐清溯源圖究竟解決了什麼問題。傳統的主機型入侵偵測系統 (Host-based Intrusion Detection System, HIDS) 大多數直接分析扁平化的系統日誌，例如逐行的系統呼叫 (System Call) 紀錄或事件紀錄檔。這種做法雖然實作簡單，但每一筆紀錄彼此獨立，缺乏因果脈絡，導致模型難以判斷一連串看似無害的操作背後，是否隱藏著具備完整攻擊邏輯的行為鏈。根據 Zipperle 等人的作品 Provenance-based Intrusion Detection Systems: A Survey [5]，將資安日誌表達成溯源圖可以透過時間、內容、行為等特徵讓模型學習如何分辨資安日誌中哪些行為是惡意行為。相較於傳統的主機型侵入偵測系統僅分析扁平的日誌，溯源圖技術透過分析因果關係和上下文，能更有效地偵測複雜的進階持續性威脅，並降低誤報率。該篇調查文獻亦特別提到，合成溯源圖的精確度與資料規模，對系統的偵測性能及運算時間效率具有高度相關性，這也呼應了本研究於第四章選用多個規模與性質互異之資料集進行實驗設計的動機。

然而，Threat Detection and Investigation with System-level Provenance Graphs: A

Survey [6] 一文中即指出，雖然溯源圖技術可以讓資安日誌在模型上得到顯著的成效，但由於溯源圖必須記錄到細緻的系統行為並且儲存大量的上下文關係，因此普遍存在處理時間過長與儲存資料量過大的問題，這個現象在資安領域中常被稱為依賴爆炸 (Dependency Explosion) 問題，就是單一事件可能會在溯源圖中繪製出成千上萬條看似相關、實則無太大意義的因果邊，使得後續分析與追溯的複雜度呈指數型成長。該篇文獻也因此設計了針對溯源圖進行資料刪減的演算法，試圖在保留關鍵因果路徑的前提下，盡可能壓縮圖的規模，藉此彌補上述缺點。

從實作的角度來看，溯源圖的取得通常仰賴作業系統層級的稽核機制，例如 Linux 平台常見的 Linux Auditd 或 CamFlow [7]，以及 Windows 平台的事件追蹤機制 (Event Tracing for Windows, ETW)。這些底層日誌錄製工具負責將行程、檔案、登錄檔與網路端點之間的互動行為記錄下來，再由溯源圖演算法將其組裝為圖結構。本研究第三章所採用之 KELLECT [8] 工具，即是奠基於 ETW 之上、針對 Windows 核心事件所設計的高效無損擷取工具；而本研究對溯源圖之形式化定義 (3.1.1 節)，亦是承接本節所回顧之文獻脈絡，將節點劃分為行程、檔案、登錄檔與網路端點四類，並以時間戳記與操作類別做為邊之定義，以避免上述依賴爆炸問題對本研究後續特徵萃取造成過大的負擔。整體而言，溯源圖技術為後續章節所探討的相關文獻提供了一個共通且具備因果語意的資料前處理作法，這也是本研究選擇以溯源圖做為本研究前處理核心的主要原因。

2.2 異常偵測技術分析

在入侵偵測與進階持續性威脅相關研究中，基於溯源圖的異常偵測技術經歷了從專家規則偵測、圖譜壓縮到深度特徵學習的演進。這個演進脈絡其實反映了研究者對於如何在不倚賴大量標記攻擊資料的前提下，仍能有效辨識異常這個核心問題的持續探索，早期方法仰賴人工制定的規則與已知威脅模型，中期方法試圖以更輕量的圖結構表示法降低運算與儲存成本，而近期方法則轉向深度學習，期望模型能以學習的方式分類出正常行為與異常行為，甚至是將異常行為投射到 Mitre Att&ck [4] 框架。以下將依據其偵測機制與解決辦法，歸納為三個主要發展方向逐一說明

2.2.1 基於專家規則的偵測方法

早期基於已知威脅模型的溯源圖分析技術，主要仰賴資訊流追蹤與圖譜比對。SLEUTH [9] 系統透過將資安日誌轉換為溯源圖，並結合標籤式 (tag-based) 的資訊流追蹤機制，

為每個系統實體賦予信任標籤與資料敏感度標籤，再依循事先定義的來源 (source / sink) 規則，即時判斷不被信任的操作行為是否被應用於敏感資料，藉此重建攻擊場景。為了緩解前章所述的依賴爆炸問題，SLEUTH [9] 進一步引入了執行分割 (Execution Partitioning) 的概念，將長時間執行的行程依照其因果相依關係切分為多個較小的執行單元，使得追蹤範圍不會無限擴張導致依賴爆炸。

HOLMES [10] 則進一步將此概念延伸，其核心貢獻在於提出高階資安場景圖 (High-level Scenario Graph, HSG) 的概念，透過關聯系統中可疑的惡意節點，將個別低階可疑事件對應至攻擊鏈 (Kill Chain) 中的特定階段，藉此把原本零散的惡意行為串接成具備完整攻擊脈絡的場景，也讓資安分析人員得以從宏觀角度理解攻擊者的整體行動軌跡，而非止於部分的異常感知。

此外，POIROT [11] 引入了不精確圖譜模式匹配 (Inexact Graph Pattern Matching) 技術，其做法是先將外部的網路威脅情資 (Cyber Threat Intelligence, CTI) 透過自然語言處理轉化為描述攻擊行為的查詢圖 (Query Graph)，再運用網路對齊 (Network Alignment) 演算法，將此查詢圖與由審計日誌所建構的溯源圖進行比對，即便兩者在細節上存在些微差異，仍可找出相似程度最高的子圖，達成主動式的資安威脅獵捕。

整體而言，這類基於專家規則與已知知識的方法，在偵測已知攻擊手法與還原攻擊路徑上，具有相當高的可解讀性，畢竟其判斷依據本來就來自專家事先定義的規則或情資，自然容易被資安人員理解與使用。然而這也正是此類方法最大的侷限所在：其偵測成效高度仰賴專家知識的完備程度與規則制定的品質，一旦攻擊者採用尚未被納入規則庫的新型手法，或刻意規避既有的標籤傳播路徑，這類系統便可能完全失效。此外，人工制定與維護大量的偵測規則本身即是一項耗時費力的工程，難以隨著攻擊技術的快速演變而即時更新，這也是後續研究轉向資料驅動方法的重要動機之一。

2.2.2 基於溯源圖結構的偵測方法

為應對 APT 攻擊潛伏期長且系統日誌資料量龐大所帶來的運算與儲存壓力，部分研究轉向探討圖結構的輕量化特徵提取與無監督學習。StreamSpot [12] 針對異質圖 (Heterogeneous Graph) 資料，提出了一種兼具記憶體與時間效率的異常偵測方法，該作品透過擷取每個節點周遭的局部子圖結構特徵，並利用雜湊技術將其轉換為固定長度的草圖 (Sketch) 向量，如此一來即可在串流資料不斷湧入的情況下，以低成本的方式持續更新每張局部子圖的向量表示，並透過與訓練過的叢集 (Cluster) 中心的距離來判斷是否為離群的異常圖。

延續此輕量化思維，UNICORN [13] 將直方圖草圖技術 (HistoSketch) 應用於長時間運行的系統環境，其架構設計在於不僅描繪單一時間點的快照 (Snapshot)，而是持續追蹤圖結構隨時間演進的變化，將龐大且不斷演進的溯源圖壓縮為精簡的草圖，以利於執行無監督的異常偵測。UNICORN [13] 透過建立系統運行時的正常行為模型，成功在不依賴專家規則的情況下，辨識出偏離正常演進軌跡的未知異常活動，這類技術大幅降低了運行時的系統成本，也提升了偵測架構在實際環境中長時間運行的可行性。

不過，在這類文獻中有一個共通的取捨：草圖或叢集式的表示法雖然大幅降低了運算與儲存成本，但也犧牲了一定程度的語意細節，這些方法大多只能在溯源圖的層級給出一個異常分數，卻難以進一步指出溯源圖中究竟是哪一個節點、哪一段行為導致異常，對於後續需要精確定位攻擊路徑的鑑識工作而言，可解釋性待改進。

2.2.3 基於深度學習結構的偵測方法

隨著深度學習技術的成熟，基於圖神經網路 (Graph Neural Network, GNN) 的特徵學習架構 (Representation Learning) 成為突破異常偵測精準度的關鍵。THREATTRACE [14] 利用歸納式圖神經網路 (Inductive GNN，例如 GraphSAGE 架構) 針對節點層級進行學習，使其能夠在缺乏對特定攻擊的背景知識下，直接於圖中精準定位惡意節點，而非僅給出圖層級的偵測結果，這也回應了前段所提及的草圖式惡意偵測方法在可解釋性與惡意偵測的細緻度上的不足。

為了進一步解決 GNN 面臨龐大溯源圖時所遇到的擴展性 (Scalability) 問題，FLASH [15] 結合了 Word2Vec 詞向量技術以捕捉行程與檔案名稱之間的語意屬性，並巧妙設計了預先計算 (Pre-computation) 機制與節點嵌入快取 (Node Embedding Caching) 策略，使系統無需在每次偵測時都重新計算所有節點的嵌入向量，有效提升了運行該架構時的特徵生成效率，讓深度學習方法可以真正應用在巨量規模的日誌資料上。

MAGIC [16] 則採用了掩碼圖表徵學習 (Masked Graph Representation Learning) 架構，其概念借鏡了自然語言領域近年盛行的遮蔽語言模型，透過刻意遮蔽圖中部分節點或邊、再要求模型重建這些被遮蔽的資訊，以自我監督的方式迫使模型學習到系統正常行為的深層結構規律，藉此強化模型對隱蔽性極高的 APT 威脅的辨識能力。這些方法顯著強化了系統對節點間的因果關係與時間關係特徵的深度理解，也讓異常偵測從過去仰賴人工規則或統計特徵逐步走向能夠自動學習複雜行為模式的先驅嘗試。

然而，即便是這些深度學習方法，仍舊停留在異常與否的判斷層次，即使以上作品

能以更高的精準度找出可疑節點或子圖，卻普遍未能進一步說明此異常行為究竟對應到 MITRE ATT&CK 框架中的哪一項具體技術。對資安分析人員而言，光是知道某個節點異常，仍不足以判斷後續的應變策略，仍需耗費大量人力進行後續的數位鑑識與人工比對，這正是本研究於第一章所指出「缺乏語意理解能力」此一研究問題的具體展現，也是本章接下來要介紹之攻擊偵測技術試圖填補的空缺。

2.3 攻擊偵測技術分析

承接上一節的討論，近年來已有一批研究不再滿足於單純的異常偵測，而是致力於將偵測結果進一步對應至具體的攻擊技術 (Techniques, Tactics, and Procedures, TTPs)，以賦予系統解釋攻擊行為的能力為目標。這其實正是本研究認為最貼近實務資安鑑識需求的方向，因為對第一線的資安分析人員而言，得知確切攻擊技術 TTP 相較於僅得知異常與否對於資安鑑識而言是一大助力，不僅能節省鑑識人力與時間，也能進一步有助於實時資安威脅偵測系統的開發。

KAIROS [3] 指出現有系統在偵測邊界中 (例如跨應用程式行為)、對未知攻擊的泛化能力、即時性以及攻擊重建的可讀性上，往往難以兼顧。該研究致力於提出一個實用且全面的入侵偵測框架，透過建構全系統溯源圖 (Whole-system Provenance)，並結合編碼器—解碼器架構學習圖中節點與邊隨時間演變的結構模式，不僅能在不依賴先備知識的情況下檢測異常，還能將複雜的圖譜自動摘要為資安人員較易理解的攻擊故事線 (Attack Story)。這也反映出現今的溯源圖異常偵測領域，正逐漸從單一的演算法優化，走向結合高精準度特徵學習、低誤報率與強大資安鑑識能力的整合性防禦架構，與本研究第三章所提出之漸進式架構設計理念相符。

AIRTAG [17] 則直接從資安日誌文本中提取攻擊特徵，而非透過建構圖結構。該研究將系統日誌視為一種具備特定語法結構的序列資料，透過定義資安日誌節點間的語義關聯來識別潛在威脅。AIRTAG 採用無監督學習架構，利用改進後的 BERT 模型對大量良性日誌進行預訓練，藉此掌握正常行為的語義分佈；偵測階段則將日誌轉化為特徵向量，並透過單類別支撐向量機 (One-Class SVM, OC-SVM) 識別離群值。此種做法的優勢在於避開了圖建構過程中的運算開銷，並能有效捕捉隱藏在檔案路徑或參數修改中的攻擊特徵，這種以 BERT 搭配 OC-SVM 的兩階段設計，與本研究 3.4.1 節所採用的 One-Class SVM 的異常偵測開門，在方法上有一定程度的借鏡，這也從側面印證了以自監督特徵學習搭配單類別分類器是當前處理攻擊樣本稀缺問題的一種穩健且被廣泛驗證的設計。

SLOT [2] 則針對 APT 攻擊者透過模仿良性行為以規避偵測 (Mimicry Attack) 的問題，提出了一套基於溯源圖與圖強化學習 (Graph Reinforcement Learning) 的偵測架構。該研究對於攻擊的定義不僅止於單一節點的異常，而是強調系統節點間多跳 (Multi-hop) 的潛在行為聯繫。其偵測原理首先透過注意力機制與多臂賭博機強化學習 (Multi-Armed Bandit) 演算法，在龐大的溯源圖中動態選擇最具代表性的鄰居節點，以過濾攻擊者刻意注入的干擾雜訊；接著系統結合半監督學習 (Semi-supervised Learning) 來強化少樣本情況下的偵測能力，透過計算標籤相似度來擴展對未知變種攻擊的識別範圍，從而實現對複雜攻擊鏈的精準重構。SLOT 這種動態選擇鄰居以處理雜訊的設計思路，其實也與本研究第三章 3.4.2 節 MultiHop 模組具有相似的借鏡，兩者都體察到溯源圖中並非所有 k 跳鄰居都同等重要，必須有選擇性地聚合資訊，才能避免無關的圖結構雜訊影響具備因果意義的子圖。

TREC [18] 的研究重點在於從廣泛的異常偵測進階到具體的攻擊技術識別，該作品解決的問題是攻擊樣本稀缺性導致傳統監督式模型難以訓練。該研究將攻擊定義為溯源圖中具有特定拓撲特徵的技術子圖 (Tactic / Technique Subgraph)，並透過定義惡意節點 (Nodes of Interest, NOIs) 來縮小分析範圍，避免對整張龐大的溯源圖進行窮舉式搜尋。該作品的偵測原理採用少樣本學習 (Few-Shot Learning) 框架，利用自注意力圖神經網路 (Self-attention GNN) 提取子圖的結構特徵，並透過孿生網路 (Siamese Network) 計算未知樣本與已知 TTP 樣本間的距離，藉此判斷兩者是否屬於同一種攻擊技術。這種設計使系統不需要大量的惡意樣本即可將零散的系統日誌對應至 MITRE ATT&CK 框架中的具體技術項目，顯著提升了威脅狩獵的自動化程度與可解釋性，也正是本研究第三章所參考重現之對照基準之一。

ZOOMER [19] 則是一個基於雙模型架構溯源圖學習的多顆粒度 TTP 識別系統，旨在解決現有方法在邊界劃分與顆粒度語義識別上的挑戰。在做法與架構上，系統首先將審計日誌建構為溯源圖並定位出異常的可疑節點，接著使用具備時間感知能力的深度優先遊走法與啟發式剪枝技術，採樣出邊界相對清晰的 TTP 子圖，隨後結合負責提取高階結構語義特徵的圖注意力網路，以及負責記憶入侵指標 (Indicators of Compromise, IoC) 等領域先驗知識的廣義線性模型，共同生成高鑑別度的子圖特徵向量，最終輸入原型網路 (Prototypical Network) 中進行少樣本的模式匹配，以預測多顆粒度 (例如同時涵蓋 Tactic 與 Technique 兩個層級) 的 TTP 標籤。

整理上述五篇文獻後，無論是透過編碼器—解碼器架構自動摘要攻擊故事線的 KAIROS [3]、避開圖結構直接處理日誌文本的 AIRTAG [17]、以強化學習動態篩選鄰居的 SLOT [2]，抑或是採用少樣本學習框架的 TREC [18] 與 ZOOMER [19]，這些方法都試圖在攻

擊樣本稀缺與攻擊手法演變這兩個現實限制之下，盡可能精準地將偵測結果對應至具體的 TTP 標籤。然而，這些方法皆仰賴溯源圖本身的結構特徵（拓撲、時間、頻率等），對於節點背後所隱含的高階語意則相對著墨較少，往往僅以節點名稱字串本身做為特徵輸入。這也正是本研究認為仍有發揮空間之處：若能在既有的結構特徵之外，額外引入具備世界知識的語意表示，理論上應能進一步強化模型對合法應用程式的常規行為與偽裝成合法行為的惡意操作兩者之間的分辨能力，這同時也呼應了第一章所提出之第二項研究問題。

2.4 資安日誌與指令嵌入模型之演進與分析

在面對資安威脅偵測時，許多研究會將非結構化的系統日誌及系統資訊轉換為語意嵌入（Semantic Embedding），投射至高維空間後，再透過機器學習或深度學習等方法達到異常偵測及惡意行為預測之目的。本研究第三章所提出之特徵萃取方法（結合大語言模型敘述生成與 SecureBERT 2.0 [1] 領域嵌入）正是建立在這條研究脈絡之上，所以在此針對資安應用領域挑選幾種具代表性的語意嵌入預訓練模型進行較為深入的分析，以作為本研究方法與既有做法之間的比較。

Log2Vec [20] 將系統日誌轉化為涵蓋多種節點（如使用者、主機、行程、檔案）的異質圖，透過啟發式規則或隨機遊走演算法，捕捉節點間的互動序列，並利用類似 Skip-gram 的模型將圖結構壓縮為低維向量。這種做法的重心放在挖掘節點之間的結構性互動關係，而非深入剖析每一次操作的指令內容或參數細節，因此在面對攻擊者刻意模仿良性行為、或是將惡意指令偽裝成正常操作時，Log2Vec [20] 便容易因為僅捕捉到表面上結構相似但實際深層語意有異的互動模式，而未能察覺深層的語意差異，導致偵測效果不佳。

LogBERT [21] 則借鏡了 Transformer 架構，針對日誌的序列特性建立行為模型。其做法是先將原始日誌解析為事件模板（Event Templates），隨後利用遮蔽語言模型（Masked Language Modeling, MLM）任務，隨機遮蔽序列中的日誌關鍵字，迫使模型根據前後文預測遺失的事件，藉此學習正常系統運作下的行為序列分布。LogBERT [21] 成功克服了傳統 RNN / LSTM 架構在處理長序列時容易發生的梯度消失問題，具備更好的長距離依賴關係捕捉能力。然而這種做法在前置的日誌模板化過程中，往往會將日誌中具體的動態參數（例如特定的檔案路徑、登錄機碼、網路 IP 位址）一併過濾掉，只保留事件類型這個較粗粒度的資訊。這麼一來，模型雖然學會了事件發生的先後順序，卻可能因此喪失了判斷具體 TTP 所需的細粒度語意參數。舉例而言，同樣是一

次「寫入登錄機碼」的事件模板，寫入是無關緊要的應用程式設定，還是常見的持久化 (Persistence) 攻擊路徑，光看事件模板本身是無從分辨的，這恰恰是本研究希望透過大語言模型敘述生成 (第 3.3.2 節) 與 SecureBERT 2.0 [1] 語意嵌入所補強的地方。

CmdCaliper [22] 則採用了與前兩者截然不同的思路：其基於通用文本嵌入模型 (General Text Embeddings, GTE [23]) 並採用對比式學習 (Contrastive Learning)，透過縮短語意相似樣本對在向量空間中的距離、同時拉大與不相似樣本間的距離，使模型具備判斷指令意圖而非僅比對字面外觀的能力。CmdCaliper [22] 訓練於作者自建之 CmdDataset，這是一個利用包含 Gemini-1.0-Pro [24] 與 GPT-3.5-Turbo [25] 在內等六種大型語言模型，透過 Self-Instruct 流程自動合成的資料集，內含 28,520 對具備高度多樣性的相似指令對。筆者認為，CmdCaliper [22] 這種借助多個大型語言模型自動生成訓練語料，再以對比學習訓練輕量嵌入模型的做法，與本研究引入大語言生成節點自然語言敘述、再交由 SecureBERT 2.0 [1] 編碼的設計理念相似，都是希望借助大型語言模型豐富的世界知識，來彌補傳統嵌入方法在語意理解上的不足。

然而，CmdCaliper [22] 目前的訓練資料著重於 Windows 系統的指令字串本身，並未涵蓋溯源圖中行程、檔案、登錄機碼與網路端點等其他類型節點的語意表示，因此在面對 Linux 系統的樣本，或是需要對「行程以外」的其他系統實體進行語意判讀時，可能無法發揮最大效益，這也是本研究選擇改以更具彈性、可套用至任意節點型別的大語言模型提示詞工程做法，而非直接沿用單一指令嵌入模型的原因之一。

綜觀本節回顧之三種嵌入方法，可以發現對於透過預訓練提升審計日誌的表示能力的演進軌跡：從最初僅著重結構關係的 Log2Vec [20]，到引入序列建模能力的 Log-BERT [21]，再到近期借助大型語言模型合成訓練語料的 CmdCaliper [22]，針對資安領域的語意嵌入技術正逐步從單純的資料統計走向具備世界知識的語意理解。然而截至目前為止，尚未有研究將大型語言模型生成之上下文敘述與資安領域預訓練嵌入模型直接結合，並系統性地將語意嵌入應用於溯源圖節點的特徵表示之上——這正是本研究第三章所提出方法試圖填補的空缺。

表 2-1: 本研究與現有溯源圖偵測系統之能力比較

系統／文獻	PG	DL	FS	TL	MG	LLM	DP	ST	SL
SLEUTH [9] (2017)	✓							✓	
HOLMES [10] (2019)	✓							✓	
POIROT [11] (2019)	✓								
StreamSpot [12] (2016)	✓								
UNICORN [13] (2020)	✓								✓
THREATTRACE [14] (2022)	✓	✓							
FLASH [15] (2024)	✓	✓							
MAGIC [16] (2024)	✓	✓							
KAIROS [3] (2024)	✓	✓						✓	✓
AIRTAG [17] (2023)		✓							
SLOT [2] (2025)	✓	✓							
TREC [18] (2024)	✓	✓	✓	✓					
ZOOMER [19] (2025)	✓	✓	✓	✓	✓				
本研究 (Ours)	✓	✓	✓	✓		✓	✓		

註：PG = 溯源圖建構、DL = 深度學習模型、FS = 少樣本學習、TL = TTP 技術層級標籤、MG = 多顆粒度 TTP (同時涵蓋 Tactic 與 Technique 兩層級)、LLM = LLM 語意敘述生成、DP = 資安領域預訓練語言模型嵌入、ST = 攻擊故事線重建、SL = 系統層級入侵判定。

第三章 研究方法

3.1 前處理

在本研究中，針對進階持續性威脅 (Advanced Persistent Threat, APT) 的偵測與分類，核心挑戰在於如何從巨量的審計日誌中精確提取出具備攻擊語意的結構。本節將詳細說明如何將審計日誌轉變成溯源圖 (Provenance Graph) 的處理流程。

本研究之威脅偵測系統以 Windows 主機核心層級之審計日誌為輸入，資料來源涵蓋公開之資料集 KELLECT4APT [8]、SAGA [26]。這些原始紀錄本質上是逐筆、單獨、彼此獨立記錄的事件流；若直接以逐筆事件輸入序列模型，將遺失事件之間「哪個主體對哪個客體執行了何種操作」所隱含的因果與拓撲關係，而此類關係正是攻擊技術 (TTP) 判別的重要線索來源。因此，本研究前處理階段的首要任務，是將原始審計日誌資料轉換為具備明確語意結構的溯源圖 (Provenance Graph)，並以此圖做為所有下游模組共同遵循的資料型態。

前處理階段可拆解為三個依序銜接的子任務：第一為定義溯源圖之形式化資料結構；第二為將原始 JSON 事件檔解析為溯源圖，並在圖上分別萃取結構與語意的雙軌特徵；第三則是以此特徵為輸入，設計漸進式的兩階段威脅偵測系統。

3.1.1 溯源圖定義

在溯源圖中，每一個節點都代表著一個實體 (如行程 Process、檔案 File、登錄檔 Registry、通訊端 Socket)，每一條邊則代表兩個實體之間的互動行為。每一條邊可表示為 $e = (u, v, p)$ ，其中 u 為主體 (Subject)， v 為目標 (Object)，而 p 則為主體對目標的關聯行為。透過這種結構化方式，實體間的上下文資訊與長期的因果關聯得以被完整保留。

給定一台主機在觀測區間 $[t_0, t_T]$ 內所產生之核心稽核紀錄集合 $L = \{e_1, e_2, \dots, e_N\}$ ，本研究將其映射為一個有向多重圖 (directed multigraph) $G = (V, E)$ 。

節點集合 V 依系統節點型別劃分為四個互斥子集：

$$V = V_{proc} \cup V_{file} \cup V_{reg} \cup V_{sock} \quad (3-1)$$

分別對應行程 (process)、檔案/目錄 (file, directory)、登錄機碼 (registry key)，以及網路端點 (socket, IP)。例如：行程節點攜帶指令列 (Cmdline) 與行程識別碼 (PID)；檔案節點攜帶路徑；登錄檔節點攜帶機碼路徑；網路節點攜帶目的位址等。

邊集合 $E \subseteq V \times V \times O \times T$ 中，每一條邊 $e = (u, v, op, ts)$ 表示行程節點 u 於時間戳 ts 對客體節點 v 執行了操作 $op \in O$ (操作型別詞彙表，例如 RegistryQueryValue, FileIOCreate, TcpIpSendIPV4 等)。

由於同一對節點之間可能在不同時間發生多次且不同種類的操作，圖 G 在資料結構上必須以多重圖形式表示，並以元組 (op, ts) 做為邊之鍵值 (key)，其形式如下：

$$Key(e) = (op, ts) \quad (3-2)$$

透過此結構，可避免不同時間點與不同操作類型的邊被錯誤視為為同一邊，從而完整保留系統行為的因果關係與時間序列特徵。

3.1.2 溯源圖建構

本研究參考了 SLOT 及其他相關文獻針對溯源圖的建構方式，將系統日誌中的實體 (如 Process、File、Network Socket) 定義為節點 (Node)，並將實體間的操作行為 (如 Read、Write、Connect) 定義為邊 (Edge)。藉由 *Source Node* $\rightarrow$ *Relation* $\rightarrow$ *Destination Node* 的關聯方式，描繪出單一主機系統內行為的因果關係，作為後續語意轉換的基礎。

本研究定義了兩組對應 TREC [18] 與 ZOOMER [19] 之節點類別操作行為對照表 (表 3-1, 表 3-2)，此舉除了做為溯源圖形式化定義之具體實作驗證外，亦使本研究之圖結構定義得以直接與上述基準方法進行對照比較。

表 3-1: Relations extracted from ETW(Event Tracing for Windows)

System Entities	System Events
Process → Process	start, end
Process → Fileio	create, iodirenum, ioread, iofilecreate, iowrite, iodelete, iofiledelete, iodirnotify, iorename
Process → Registry	open, queryvalue, query, create, setvalue, setinformation, enumeratevaluekey, enumeratekey, kbccreate, querymultiplevalue, deletevalue, delete, kcbdelete, flush
Process → Socket	sendipv4, connectipv4, recvipv4, disconnectipv4, disconnectipv6, reconnectipv4, reconnectipv6



表 3-2: Relations extracted from Procmon

System Entities	System Events
Process → Process	processcreate, processstart, processexit, processstatistics, threadcreate, threadexit, threadprofile
Process → File	createfile, readfile, writefile, closefile, queryinformationfile, setinformationfile, querydirectory, notifychangedirectory, createfilemapping, queryeafile, seteafile, querysecurityfile, setsecurityfile, flushbuffersfile, lockfile, unlockfile, filesystemcontrol, deviceiocontrol
Process → Registry	regopenkey, regcreatekey, regquerykey, regsetvalue, regqueryvalue, regdeletevalue, regdeletekey, regenumkey, regenumvalue, regclosekey, regsetinfokey, regquerymultiplevaluekey, regflushkey, reloadkey, regunloadkey, regrenamekey
Process → Socket	tcpaccept, tcpconnect, tcpdisconnect, tcpreceive, tcpreconnect, tcpretransmit, tcpsend, tptcpcopy, udpaccept, udpconnect, udpreceive, udp send

3.2 系統架構總覽

本研究提出的系統架構旨在解決傳統入侵偵測系統缺乏語意理解能力與高誤報率的挑戰。本研究捨棄了單純依賴底層特徵的作法，改採語意增強與漸進式過濾的策略，本研究提出具有四個階段的惡意偵測模組，整體資料流如圖 3-1 所示：原始核心稽核紀錄依 3.1.1 節之定義解析為溯源圖後，進入語意增強階段，同步經過大語言模型產生自然語言敘述與結構化的審計日誌事件向量進行融合；融合後的事件特徵先通過階段一的異常偵測模型進行篩選，僅將被判定為疑似異常的事件視窗交由階段二之 TTP 威脅標記模型進行攻擊技術分類，最終輸出每個事件之 MITRE ATT&CK Technique 標籤序列。

前兩個階段（溯源圖建構、語意增強）合稱為日誌前處理與語意增強機制，對應 3.3 節；後兩個階段（異常偵測、TTP 偵測）合稱為漸進式威脅偵測系統，對應 3.4 節。之所以在偵測端採用兩階段架構（異常偵測 → TTP 偵測）而非以單一多類別分類器直接判別，其設計依據如下：

第一，效率與類別不平衡。大部分的真實攻擊場景中，良性事件與惡意事件之比例極度不平衡（在本研究之 campaign 級測試資料中，惡意事件佔比通常低於 0.1%）。若單一模型須同時判斷異常行為並且做技術偵測可能會導致單一模型任務過多而導致表現不佳，類別不平衡的問題會同時影響異常偵測與 TTP 偵測等兩個任務，將使損失函數難以兼顧兩者。採用前置的異常偵測模型，可先以較低運算成本、對召回率友善的方式排除絕大多數良性事件，僅將少數疑似異常的視窗交由運算成本較高、需精細判別 TTP 技術類別的第二階段模型，藉此同時達成運算效率與偵測精度的取捨。

第二，異常偵測與 TTP 偵測在本質上屬於兩種不同的機器學習問題。異常偵測屬於單分類（One-Class）問題，由於現實中的攻擊樣本往往稀少、未知且難以窮舉，因此模型僅能依賴良性樣本來學習正常行為的邊界，而不依賴任何攻擊標籤。相對地，TTP 偵測則屬於監督式的多類別序列標記問題，必須利用已標記的攻擊樣本進行訓練。

基於上述差異，本研究將兩者拆分為獨立的處理階段，使各階段能採用最適合的建模方式與門檻校準策略。例如在 3.4.1 節中，本研究的異常偵測門檻僅單純透過良性樣本的各式統計特徵來進行訓練，藉此確保模型更符合真實場景的偵測需求。

第三，模組化與可組合性。此漸進式設計具備工程上之可替換性：3.4.1 節之異常偵測模組本身即可獨立替換而不影響下游 TTP 偵測模組之訓練介面與資料格式，符合模組化系統設計之基本原則，也對於後續針對特定子模組進行消融實驗有利。

3.3 日誌前處理與語意增強機制

系統審計日誌雖然記錄了詳盡的底層操作，但因數量龐大且缺乏直觀的高階語意，直接分析容易受背景雜訊干擾。為此，本研究制定了一套包含圖譜建構與特徵萃取的處理流程。從原始審計日誌中獲取溯源圖所需的元素，並在圖上以語意增強的方式萃取雙軌特徵：一軌為透過大型語言模型對節點生成自然語言敘述後再由預訓練模型 SecureBERT 2.0 [1] 轉換成具豐富語意之語意嵌入，另一軌為直接對節點與邊字串進行 SecureBERT 2.0 [1] 轉換為語意嵌入並輔以主成分分析降維。兩軌特徵於事件層級串接融合，做為 TTP 偵測模型的輸入。

3.3.1 結合 LLM 之自然語言敘述生成

為了解決底層日誌缺乏高階上下文的問題，本研究引入大型語言模型使底層日誌具有豐富的高階語意。系統會將建構好的溯源圖行為路徑輸入至大型語言模型，透過提示詞工程 (Prompt Engineering) 讓模型根據節點屬性與操作順序，生成具備邏輯連貫性與上下文資訊的中立自然語言敘述，將系統日誌轉化為人類與模型皆易於理解的行為描述。

SecureBERT 2.0 為預訓練於資安領域語料的 BERT 編碼器，然而溯源圖節點之原始識別字串（例如執行檔路徑、登錄機碼、IP 位址）本身通常極短、高度稀疏，且彼此之間缺乏可供編碼器擷取的上下文語意——例如 `C:\Windows\System32\cmd.exe` 與 `C:\Windows\System32\wscript.exe` 在字面上高度相似，但兩者代表的行為語意不同，直接嵌入原始字串未必能充分區分。本研究在 SecureBERT 2.0 編碼之前，插入一個以 LLM 為基底的知識擴充步驟：先將 LLM 透過節點資訊作為輸入，生成一段根據大語言模型通用背景知識所生成的自然語言敘述，再交由 SecureBERT 2.0 預訓練模型，目的在於將該執行檔在公開資料來源之中所述的特徵與應有行為作為資安預訓練模型的輸入並產生語意嵌入，這是單純對字串做子詞 (subword) 嵌入所難以取得的資訊。

大語言模型敘述生成套用於溯源圖中所有型別之節點，包括行程 (Process)、檔案 (File)、登錄機碼 (Registry)、網路端點 (Network) 等節點。不同於僅使用原始節點識別字串作為輸入，本研究將各節點之型別資訊與其對應之識別內容一併提供給大語言模型，使其根據節點型別與背景知識生成對應之自然語言描述。例如，對於行程節點可描述其一般功能與常見操作；對於檔案節點則說明其可能代表之系統元件或資料檔案；對於登錄機碼則描述其於 Windows 系統中常見之用途；對於網路端點則描述其所代表之網路資源或通訊對象。藉由將不同型別節點皆轉換為具有一致語意表示之自然語言敘述，

可使後續 SecureBERT 2.0 在編碼時獲得較完整之語意資訊，而非僅依賴高度稀疏且缺乏上下文之原始識別字串。

提示詞明確要求 LLM 僅根據廣泛已知且有文件根據的知識以及路徑本身所包含的資訊 (System32 代表作業系統執行檔、Program Files 代表已安裝應用程式、AppData 代表使用者層級安裝之元件) 進行描述，並訂立四條硬性規則 (R1-R4):

- R1 僅使用廣泛且公開的資料來源作為背景知識，描述該節點一般而言是什麼形式、通常執行何種操作；
- R2 使用具體技術詞彙 (如「載入服務 DLL」、「渲染網頁內容」、「解譯.ps1 指令碼」)，避免空泛敘述；
- R3 維持中性、現在式、事實性語氣，明確禁止出現 suspicious、malicious、benign、anomalous、attack、legitimate 等判斷性詞彙，也禁止 might / could / may / possibly 等模稜兩可的用語；
- R4 僅輸出至一個符合既定 schema 的 JSON 檔案，不得包含 Markdown 格式或 JSON 以外的任何文字。

此設計之核心目的，在於防止 LLM 於敘述插入良性與惡意的主觀判斷，若敘述文字本身即帶有傾向性字眼，下游偵測模型將可能學會辨識大語言模型的用詞偏好而非真正的行為語意，形成模型在學習上的困難，使實驗結果大打折扣。透過強制大語言模型僅輸出可驗證、可追溯至公開資料來源的內容，本研究得以確保語意增強所引入的資訊，是對威脅偵測具真正建設性的背景知識，而非變相注入答案。

LLM 被要求輸出符合固定 schema JSON 物件，包含 name (執行檔名稱)、category (OS binary | installed application | user-installed component | unknown user-mode application 四種類別之一)、description (描述文字) 與 standard_operations (標準操作列表) 四個欄位。系統以正規表示式擷取 JSON 區塊並解析，若解析失敗則以原始文字作為輸入，確保後續架構在面對格式不合規之 LLM 輸出時仍可執行，不因單筆失敗生成而中斷整體流程。解析後之 JSON 內容會被攤平串接為一段純文字，交由後續 SecureBERT 2.0 [1] 編碼。

本研究特別選定三個具代表性之開源大型語言模型作為語意特徵萃取的基底，分別為 Qwen2.5-7B-Instruct [27]、Llama-3.1-8B-Instruct [28] 以及 Mistral-7B-

Instruct-v0.3 [29]。此三款模型在 7B 至 8B 參數級別中皆展現了卓越的文本推論與指令遵循能力，且各自具備不同的底層架構設計與訓練語料。透過導入並交叉比對這三款模型，本研究旨在深入檢驗更換大語言模型主幹對下游異常偵測與 TTP 偵測的影響，藉以評估何種開源模型最能精準捕捉溯源圖中的系統行為語意。

考量到在本地端載入 Llama-3.1-8B-Instruct [28] 等模型仍需耗費不小的硬體資源，系統特別加入了輕量化的資產與連線前置檢查。在每一次的描述生成流程開始前，系統會先行確認指定的開源模型權重是否可存取、API 金鑰是否有效，以及 GPU 記憶體是否足以完整載入該模型。此作法有效避免了因設定錯誤而浪費運算資源。

3.3.2 基於 SecureBERT 2.0 的特徵萃取

本研究之特徵萃取採雙軌並行設計：(a) 事件向量，直接對節點與邊的原始字串進行 SecureBERT 2.0 [1] 嵌入做為主要特徵；(b) 大語言模型語意向量，對大語言模型生成之自然語言敘述進行 SecureBERT 2.0 [1] 嵌入，做為原始字串嵌入的背景知識補充。

(a) 事件向量 首先於訓練語料中收集節點與邊的詞彙表：依據節點類別對照表 (Process → Cmdline、File → Name、Registry → Key、Network → Dstaddress) 取出每個節點所屬字串，並收集所有出現的關係字串。詞彙表中每一字串以 SecureBERT 2.0 [1] 進行編碼。在此過程中採批次分詞，每批次動態填補至批次內最長序列，以避免對整體詞彙表取最長序列造成記憶體浪費，並對最後一層隱藏狀態依注意力遮罩 (attention mask) 做平均池化 (mean pooling)，得到 768 維原始嵌入：

$$\text{emb}(s) = \frac{\sum_t m_t \cdot h_t}{\sum_t m_t}, \quad h = \text{SecureBERT2.0}(s) \quad (3-3)$$

其中 h_t 為第 t 個子詞位置之隱藏狀態， m_t 為對應之注意力遮罩值。為降低下游模型輸入維度並過濾雜訊，本研究對節點嵌入與邊嵌入分別以主成分分析 (PCA) 降維至 256 維與 16 維，並將擬合完成之 PCA 基底持久化保存，確保訓練與推論階段使用同一組降維基底，避免基底不一致所導致之特徵空間偏移。

每筆事件的特徵結構為來源節點嵌入、邊嵌入與目的節點嵌入之串接 (concatenation)：

$$\mathbf{x}_{\text{struct}} = \text{node_emb}(src) \oplus \text{edge_emb}(op) \oplus \text{node_emb}(dst) \in \mathbb{R}^{528} \quad (3-4)$$

(b) LLM 語意向量 針對同一節點的資訊，改以大語言模型生成的自然語言敘述進行 SecureBERT 2.0 平均池化嵌入。得到 768 維語意向量後，同樣以 PCA 降維至 128 維。每筆事件之語意增強來自於來源節點與目的節點的語意向量之串接：

$$\mathbf{x}_{llm} = llm_emb(src) \oplus llm_emb(dst) \in \mathbb{R}^{256} \quad (3-5)$$

最終送入偵測模型之逐事件複合特徵為兩通道之串接：

$$\mathbf{x} = \mathbf{x}_{struct} \oplus \mathbf{x}_{llm} \in \mathbb{R}^{784} \quad (3-6)$$

設計依據與成本考量 本架構採用凍結編碼器 (frozen encoder) + 離線批次嵌入 + PCA 降維而非端對端微調 SecureBERT 2.0，是在本研究運算資源條件下，兼顧特徵品質與訓練成本之選擇：詞彙表僅需編碼一次，後續所有訓練與推論皆以查表方式取用嵌入，避免每個訓練步都須重新產生嵌入。此外，本研究前期以探測實驗 (probe_structured) 比較兩種特徵之 held-out-instance 技術遷移準確率，發現 528 維結構化特徵可達 58.96%，顯著優於原始 768 維平均池化 SecureBERT 嵌入之 39.83% (約提升 19 個百分點)。此為本研究以結構化 528 維向量做為主要特徵通道、並將 LLM 語意向量作為輔助增強特徵而非取代結構化特徵。

3.3.3 異常偵測 (Anomaly Detection)

異常偵測是第一階段的粗篩，目的在於盡可能的在大量系統日誌中篩選出必要的惡意節點並送進下一階段的 TTP 偵測，異常偵測的訓練與門檻校準只使用良性樣本，貼近真實情況下惡意樣本稀少且型態未知的狀況。本研究以 TREC [18] 和 ZOOMER [19] 作為借鏡並實作比較三種變體：

(i) Prototype Encoder

此方法不用訓練任何模型，直接拿現成的 embedding 做距離比對。做法是：每個攻擊技術類別，把訓練集裡屬於這一類的事件 embedding 取平均，當作該類別的「代表點」 P_c ；良性樣本因為沒有明確的類別可以分，就先跑一次 K-means ($k = 64$) 分成 64 群，取每一群的中心點 BK_k 當成良性代表。有了這兩組代表點之後，攻擊分數就定義成：

$$attackness(\mathbf{x}) = \max_c \cos(\mathbf{x}, P_c) - \max_k \cos(\mathbf{x}, BK_k) \quad (3-7)$$

以上公式在計算兩件事：事件跟「最像的那個攻擊類別」有多像，減掉它跟「最像的那個良性群」有多像。如果前者比後者高，代表這筆事件離攻擊的代表點比較近、離良性的代表點比較遠，分數就會是正數，正數表示可疑；反之如果分數是負的，代表它比較貼近良性。此設計的好處是分數本身不用在乎攻擊的類別，只在乎相對來說比較像良性還是攻擊，剛好符合第一階段重點在於粗篩、不需判斷具體技術。

(ii) Siamese Network

此方法使用自監督對比學習訓練一個編碼器。作法是先把良性事件切成一段一段的滑動視窗（長度 256、每次移動 64 個事件），對同一段視窗做兩種不同的干擾，產生兩個「看起來不太一樣但其實是同一件事」的版本——一個把部分特徵隨機丟掉（機率 $p = 0.15$ ），一個加一點高斯雜訊（ $\sigma = 0.05$ ）。這兩個版本會被丟進同一組權重的雙向 2 層 GRU，做遮罩平均池化跟 LayerNorm 得到視窗的特徵，再經過一個投射層壓成 $\mathbf{z}_1, \mathbf{z}_2 \in \mathbb{R}^{64}$ 並做 L2 正規化。訓練用的是 NT-Xent 損失函數：

$$\mathcal{L}_{\text{NT-Xent}} = -\log \frac{\exp(\text{sim}(\mathbf{z}_i, \mathbf{z}_j)/\tau)}{\sum_{k \neq i} \exp(\text{sim}(\mathbf{z}_i, \mathbf{z}_k)/\tau)}, \quad \tau = 0.1 \quad (3-8)$$

這條公式的分子是同一視窗的兩個增強版本的相似度，分母是這兩個版本跟其他所有視窗的相似度加總。要讓 loss 變小，模型就得想辦法把分子變大（同一段視窗的兩個版本要愈像愈好）、把分母變小（跟別的視窗要愈不像愈好），訓練到最後模型就會學到如何將同一事件特徵在向量空間會被拉近，不同的事件會被推開，而且因為從頭到尾只餵良性視窗，此空間的形狀完全根據良性行為建構。透過學習之後定義出來的向量空間作為定義未知事件的依據。

(iii) One-class SVM

此方法的特徵就是集結 528 維的事件向量之中每一維的平均值（528 維）、最大值（528 維）、標準差（528 維）與該事件的節點內容在整個日誌裡面出現的次數（1 維）外加一項維度表示該事件節點是否在訓練集出現過（1 維），為 1586 維的行程級特徵。 ν 值測試了 $\{0.001, 0.002, 0.005, 0.01, 0.02, 0.05\}$ 。本研究使用 Nystroem 近似法與 SGDOneClassSVM，這樣就不需要花費到 RBF $\mathcal{O}(n^2)$ 的計算量。資料切分是良性 70% / 10% / 20% (train/val/test)，惡意樣本則是 0% / 50% / 50%。

總結來說，這三種方法分別代表不同的學習策略與成本考量：Prototype Encoder 不需訓練模型，直接利用現成的 embedding 計算特徵向量之間在向量空間中的距離，此方法對於成本而言具有較大優勢；Siamese Network 則需要投入時間與算力訓練每個資料集專屬的編碼器，藉此讓特徵空間更貼合良性資料的分佈，但相對的增加調整超參數的複雜

度；One-class SVM 則作為本研究的主要架構，完全不依賴特徵學習，單純使用原始的統計特徵來進行異常偵測。

本研究比較這三種做法的目的在於評估異常偵測階段需花費的算力與方法在 SAGA dataset [26] 上是否符合效益，以及為了在 TTP 偵測的階段可以獲取最完整且準確的惡意節點篩選，以達到後續 TTP 偵測的計算效益最大化及整體威脅偵測的精確性。

3.3.4 TTP 偵測 (TTP Detection)

階段二的核心目標是針對已通過異常偵測篩選的異常事件進行深入分析，並輸出對應的 TTP 攻擊技術標籤序列。在模型輸入的設計上，系統會接收一段長度為 W 的事件視窗。視窗內的各個事件皆會轉換為 3.3.2 節所述的特徵向量 $\mathbf{x}_t \in \mathbb{R}^D$ ，以及 3.1.1 節定義的圖鍵 (g_a, g_b) ，藉此協助模型追蹤事件在溯源圖中的結構關聯。

多尺度上下文前處理 本研究並未將事件特徵一條條直接送入 Transformer，而是先經過一個多尺度模組，使每個事件在進入自注意力機制前，即可同時取得自身與短、中、長不同長度的上下文資訊。其設計動機在於完整的惡意攻擊往往在不同時間或結構上組成，所以對於多時間尺度的資訊整合可以讓架構的輸出對於長時間跨度的惡意攻擊更有利，以下依據惡意樣本的行爲統計將惡意攻擊分成以下三類：單一觸發性操作（一次可疑的登錄機碼寫入）、短期攻擊行爲（以腳本行爲執行行爲的數個連續事件），以及跨越更長時間距離的多步驟攻擊，三者所需的視野大小並不相同。本研究提供兩種方法做到多尺度的上下文前處理：

(一) MultiChunk (時間多尺度) 針對每一個時間尺度 s ，系統會提取範圍大小為 s 的局部上下文資訊。在實作上，本研究獨立處理各尺度特徵通道的一維卷積 (Depth-wise 1D Convolution) 來執行局部特徵的聚合 (Pooling)。為了確保模型在訓練初期的穩定性，卷積核的權重會被初始化為 $1/s$ ，使其作用等同於傳統的平均池化 (Average Pooling)。同時系統搭配遮罩 (Mask) 機制，確保無效的序列填充 (Padding) 數值不會參與計算，以避免計算出的數值產生偏差。

此外，為了讓模型具備篩選資訊的能力，各個尺度通道皆設計一個可學習的權重開關 (Sigmoid Gate) $g_s = \sigma(\theta_s)$ 使模型能在訓練過程中，自動降低那些資訊量較少的時間尺度在模型中的影響力。

最後，模型會將原始輸入特徵 $\mathbf{x}_t$ 與各個尺度所提取出的局部特徵 ($\text{pool}_{s1}(\mathbf{x})_t$ 至

$\text{pool}_{sK}(\mathbf{x})_t$) 進行串接 (Concatenation)，接著送入多層感知器 (MLP) 進行特徵融合，並且正規化後作為輸出。其數學表示如下：

$$\mathbf{h}_t = \text{LayerNorm}(\text{MLP}(\mathbf{x}_t \oplus \text{pool}_{s1}(\mathbf{x})_t \oplus \cdots \oplus \text{pool}_{sK}(\mathbf{x})_t)) \quad (3-9)$$

(二) MultiHop (溯源圖 k-hop) 此方法以 3.1.1 節所定義的「溯源圖拓撲關係」來提取上下文特徵。系統會根據視窗內事件的圖鍵 (g_a, g_b) ，建立一個列正規化 (Row-normalized) 的鄰接矩陣 $\mathbf{A}$ 。

建立鄰接矩陣後，模型會透過計算矩陣的 k 次方 ($\mathbf{A}^k$)，來迭代獲取距離為 k 步的 k -hop 鄰域平均特徵，最後同樣以多層感知器 (MLP) 將不同跳數的特徵進行串接與融合。

此機制的重點在於模型不僅能感知時間上連續的事件，更能敏銳捕捉到結構上具備因果關聯但在時間軸上相隔甚遠的隱蔽事件。這不僅呼應了 3.1.1 節中溯源圖的因果連結語意，更是相對於純時間序列模型、能有效對抗潛伏性攻擊的設計。

序列編碼與解碼 多尺度融合後的特徵 $\mathbf{H} \in \mathbb{R}^{W \times 512}$ 疊加位置編碼後，送入 2 層、8-head 之 Transformer 編碼器，得到上下文特徵後再經線性層投影至各事件之類別發射分數 $\phi_t(y)$ 。發射分數可視為是每個 TTP 項和良性項在該事件的預測分數。

為確保輸出標籤序列與前後事件的偵測預測結果合理 (例如同一攻擊技術之標籤不應被無關之良性標籤任意打斷)，本研究於發射層上疊加線性鏈條件隨機場 (linear-chain CRF)，以維特比演算法 (Viterbi) 計算最大機率標籤序列，訓練時針對 CRF 架構設計的損失函數為：

$$\mathcal{L}_{\text{CRF}} = -\log p(\mathbf{y}|\mathbf{X}) = -\left[\sum_t \psi(y_{t-1}, y_t) + \sum_t \phi(y_t, \mathbf{x}_t) - \log Z(\mathbf{X}) \right] \quad (3-10)$$

其中 ϕ 為發射分數、 ψ 為轉移分數、 $Z(\mathbf{X})$ 為配分函數 (partition function，經前向演算法計算)。最後的訓練損失函數為 CRF 負對數概似與類別加權 Focal Loss 之和：

$$\mathcal{L} = \mathcal{L}_{\text{CRF}} + \mathcal{L}_{\text{Focal}}, \quad \mathcal{L}_{\text{Focal}} = \sum_t w_{y_t} (1 - p_{y_t})^\gamma \cdot \text{CE}(\mathbf{x}_t, y_t) \quad (3-11)$$

在損失函數的設定上將攻擊類別與良性類別的權重分別設為 3.0 與 1.0 主要是為了解決事件層級中極度不平衡的資料分佈。同時，我們加入了 $\gamma = 2$ 的 Focal Loss 機制，用來壓低相對較好分類的樣本 (通常是佔多數的良性事件) 對梯度的影響，強迫模型把學習重心放在比較難分辨的攻擊事件上。因為 CRF 的前向演算法會用到 log-sum-exp

運算，如果全程使用混合精度 (AMP / FP16) 訓練，很容易發生溢位 (Overflow)，導致訓練後期的損失函數結果開始震盪甚至發散。爲了克服這個問題，本研究強制將 CRF 與 Focal Loss 的計算區塊轉回 FP32 精度 (即局部關閉 autocast)，而其餘模型架構則繼續使用 FP16。這個做法能有效兼顧數值的穩定性與訓練的運算效率。

良性標記偏差校準 在實驗過程中發現模型容易過度將良性事件預測爲攻擊，導致將太多正常行爲誤標爲 TTP (即誤報率偏高)。爲了抑制這個現象，本研究在推論 (Inference) 階段設計了 O-Bias 機制，具體作法是在 CRF 解碼時，刻意爲代表正常行爲的 'O' 類別加上一個偏差值 b ，以提高發射分數裡的良行分數來降低預測爲良性的門檻：

$$\phi'_t(O) = \phi_t(O) + b \quad (3-12)$$

爲了決定 b 的最佳數值，我們在驗證集上測試了 $\{0, 0.5, 1, 2, 4, 8\}$ 這幾組候選參數。挑選原則是：在召回率 (Recall) 最多只能比原先 ($b = 0$) 下降 0.02 的容忍範圍內，選出能讓精確率 (Precision) 達到最高的 b 值。未來在實際部署時，若使用者需要調整誤報或漏報的門檻，只需微調這個偏差值，就能控制精確率與召回率的取捨。

訓練與評估切分 本研究採用 Caldera [30] 蒐集的全樣本數據集作爲訓練資料集。該資料集共涵蓋 16,900 個攻擊樣本，總計包含 7,949,998 筆系統事件；其中良性事件爲 4,146,957 筆 (佔 52.16%)，惡意事件爲 3,803,041 筆 (佔 47.84%)，在事件層級的惡意與良性類別上呈現相對均衡的類別分佈。

在資料切分方面，爲了驗證模型在真實場景下的泛化能力，SAGA dataset [26] 額外建立了一個獨立的「推論集」。這個推論集是透過 Caldera 框架模擬還原出的真實攻擊場景，裡面包含的攻擊手法挑選了與訓練資料沒有重疊的攻擊手法但是 TTP 在訓練集存在。

至於其餘的樣本，則依大約 80%、10%、10% 的比例切分爲訓練集、驗證集與測試集。在訓練過程中，我們會以驗證集在攻擊類別上的 macro-F1 分數，作爲挑選最佳模型權重的依據。這樣的切分策略，讓我們不僅能使用常規測試集來評估模型對已知攻擊分佈的偵測能力，還能用 SAGA 推論集來模擬模型面對真實世界攻擊資料時的表現，確保實驗結果客觀，避免模型單純死背特定資料而產生偏誤。

延伸架構探索與方法論意義 在確立最終架構之前，本研究也進行了一系列的實驗來探索其他架構變體，目的是爲了找出模型學習失敗的真正原因，並藉此證明我們最終的設

計是有實證依據的。

- **探針模型 (Probe Model)**

針對初期遇到的嚴重過度配適 (Overfitting) 問題，本研究改用參數量極低的「探針模型」來測試，例如單純用 PCA 搭配線性層、淺層 MLP 或是單層 Transformer。實驗發現，即使參數量大幅縮減了一個數量級，Overfitting 的情況依然存在。這讓我們明確排除了模型容量過大導致模型死記硬背的假設。

- **深度模型的捷徑學習 (Shortcut Learning) 現象**

本研究做了一個零訓練 (Zero-training) 的對照實驗：單純將同一個節點 (UUID) 的 Embedding 取平均，直接算最近鄰居相似度比對。沒想到，這種不帶任何參數學習的方法，居然就能具備一定的技術鑑別力。

進一步分析後，我們觀察到了嚴重的低秩 (Low-rank) 現象：SecureBERT 2.0 [1] 對同一節點產生的 Embedding 高度相似 (餘弦相似度 ≈ 0.94)，且 768 維中高達 95% 的變異只集中在極少數的 21 維。這說明了面對溯源圖資料，深度模型非常容易產生捷徑學習 (Shortcut Learning) 的現象。它並沒有去萃取攻擊行為的語意，而是直接死背了節點 (UUID) 的身分。

正是基於這些分析結果，本研究最終才決定捨棄直接使用高維度原始 768 維嵌入的做法，改為採用 PCA 降維後的 528 維特徵。同時透過加入 CRF 全域解碼將模型最終預測結果連結至前後預測結果，並將異常偵測作為前置模組。這些設計都是為了解決模型死背與處理資料極度不平衡所做出的策略。

3.3.5 入侵偵測 (Intrusion Detection)

系統在具有潛在威脅的情況下其實不足以證明該系統遭受到確切的入侵，作為最後的確認，此階段會整合前階段取得的 TTP 資訊進行入侵階段的綜合判斷。系統將評估該日誌內容是否具備完整的攻擊邏輯或構成真實的惡意威脅。透過此漸進式的驗證機制，系統確保只有在確認為真實攻擊時才觸發最終警報，有效過濾掉單一或無害的異常操作，大幅降低系統的誤報率 (False Positive Rate)。

因此，在第三階段是一套以累積風險分數為核心的機制：將階段二輸出的戰術標籤序列 y_t ，轉換為一個隨時間演進、可反映攻擊進展程度的總風險分數 $S(t)$ ，當此分數超過部署門檻時，系統才觸發最終警報。不同攻擊技術的基礎風險分數不應相同 (例

如 Impact 應遠高於 Discovery)，且風險分數需隨時間衰減，避免長期累積之低風險行為誤觸警報，若模型在短時間內觀測到攻擊者於多個不同攻擊階段間快速推進 (例如 Execution → Privilege Escalation → Defense Evasion)，代表攻擊鏈正在被快速推進，風險應被快速放大而非線性累加。

基礎風險分數 於時間步 t ，系統依模型預測之戰術標籤 y_t ，透過權重映射函數 $\mathcal{W}$ 查表取得該戰術之基礎風險分數：

$$R_{\text{base}}(t) = \mathcal{W}(y_t) \quad (3-13)$$

其中 $\mathcal{W}$ 依 ATT&CK [4] 攻擊鏈生命週期的階段順序遞增設定在於愈接近攻擊鏈後期 (例如 Exfiltration、Impact) 之戰術，其基礎風險分數愈高，愈前期的偵察類戰術 (例如 Discovery) 則風險分數較低，藉此讓分數的定義即反映攻擊進展之嚴重程度與系統受到的威脅程度。

近期戰術多樣性與鏈式擴增乘數 系統以回溯視窗大小 K 定義一個相異戰術集合，統計最近 K 個時間步內，扣除良性標籤 (O) 後所觀測到的相異戰術種類：

$$\mathcal{U}(t) = \{ y_i \mid i \in [t - K + 1, t] \wedge y_i \neq O \} \quad (3-14)$$

並依集合大小 $|\mathcal{U}(t)|$ 定義風險擴增乘數：

$$\mathcal{M}(t) = 1.0 + \alpha \cdot |\mathcal{U}(t)| \quad (3-15)$$

其中放大係數 α 控制擴增幅度。此設計之依據在於：若近期視窗內僅重複出現單一戰術，代表攻擊者行為單一、尚未明顯推進攻擊鏈，乘數應接近基準值 1.0；反之，若短時間內偵測到多種不同戰術交替出現，代表攻擊者正快速跨越攻擊鏈之多個階段，此時即便單一戰術的基礎風險不高，仍應賦予快速放大的風險分數。

風險增量與累積總分 時間步 t 的風險增量，定義為基礎風險與鏈式擴增乘數之乘積：

$$\Delta S(t) = R_{\text{base}}(t) \times \mathcal{M}(t) \quad (3-16)$$

系統的總風險分數 $S(t)$ 則以指數衰減之方式累積歷史分數與當下增量：

$$S(t) = \gamma \cdot S(t-1) + \Delta S(t) \quad (3-17)$$

其中衰減因子 $\gamma \in (0, 1)$ 控制歷史分數消散的速度： γ 愈小，代表愈早期風險增量對當前總分的影響愈快消退，藉此避免長時間跨度下、彼此不相關的零星低風險行為被錯

誤地線性累加至觸發警報之程度； γ 愈接近 1，則系統對長期潛伏、緩慢推進之攻擊鏈愈敏感。此一遞迴形式亦使 $S(t)$ 之更新僅需前一時間步之分數與當下觀測，具備串流 (streaming) 運算的低延遲特性。

判定規則與輸出 系統持續追蹤 $S(t)$ ，當其超過預先設定的門檻 θ_{alarm} 時，判定該時間段構成確認入侵並觸發最終警報，未超過門檻前， $S(t)$ 僅做為系統內部持續追蹤的風險指標，不主動中斷或干擾資安人員既有的工作流程。相較於階段二單純逐事件輸出技術標籤，此一累積風險分數機制欲使最終警報之觸發條件建立在攻擊是否隨時間持續且加速推進，此設計更貼近真實攻擊生命週期意義的判定，而非任一單一時間步的技術標籤本身。

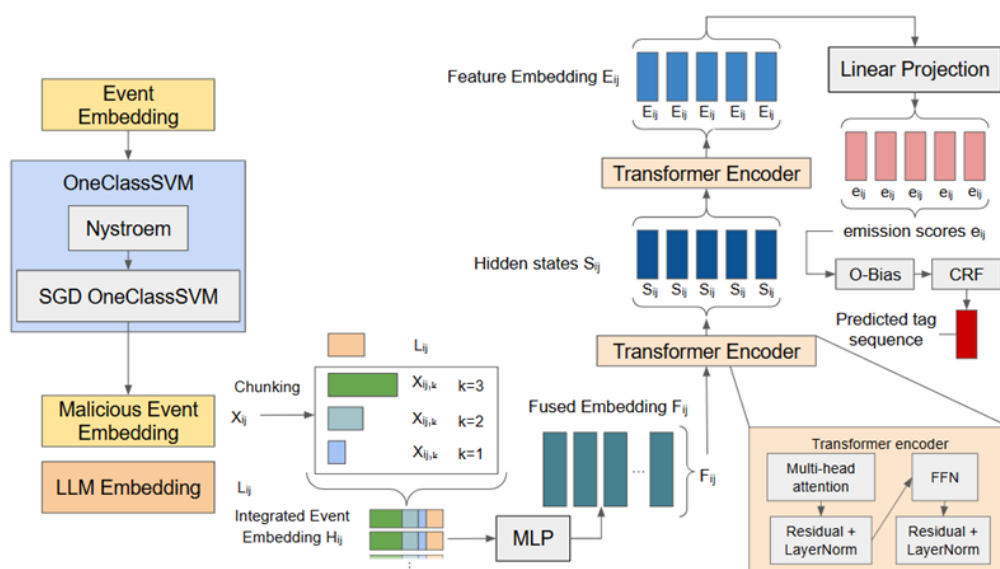


圖 3.1: 系統架構圖

第四章 實驗設計

4.1 訓練環境與參數設置

本節說明本研究所使用的軟硬體訓練環境，以及各架構的參數設置，作為後續實驗結果重現與比較的依據。

硬體方面，本研究的訓練工作歷經了兩個階段的設備更迭。專案初期模型訓練主要於配備 NVIDIA GeForce RTX 4090 的工作站上進行，後續遷移至配備 NVIDIA GB10 (Grace-Blackwell 架構) 的 DGX Spark 設備，具備 128GB 記憶體與 20 核心 ARM 架構處理器。針對此次硬體替換的差異，程式碼中也設計了對應的自適應機制：訓練批次大小與學習率會依偵測到的 GPU 是否具備 Blackwell 架構記憶體特性而動態調整 (記憶體環境下批次大小由 48 提升至 192、學習率由 1.5×10^{-4} 提升至 3×10^{-4})，所有訓練均固定使用單一 GPU，資料則存放於掛載的 12TB 硬碟，以因應大規模稽審計日誌與嵌入向量的儲存需求。

軟體方面，程式碼以 Python 3.11 開發，主要依賴套件包含 PyTorch、scikit-learn、torchcrf (線性鏈條件隨機場實作)、NetworkX (溯源圖資料結構)、pandas 等。

為確保實驗結果的可重現性，絕大多數訓練腳本採用種子值 42，並固定使用單一 GPU 執行。混合精度訓練方面，依模型特性採取兩種不同策略，由於 CRF 前向演算法的 log-sum-exp 運算在 FP16 精度下容易發生數值溢位，因此除主體 Transformer 編碼部分採用 bfloat16 自動混合精度加速訓練外，CRF 損失與 Focal 損失的計算則強制以 FP32 精度執行；其餘異常分類與對比學習模型，則視情況搭配梯度縮放器與梯度裁剪以維持訓練穩定性。

4.2 資料集

本章說明本研究的實驗設計，內容包含所採用的兩個進階持續性威脅（APT）相關資料集、TTP 偵測任務的比較基準與評估方式，以及威脅偵測系統層級的比較基準與評估方式。各資料集與比較基準的選定，皆以第三章所述的溯源圖建構、語意增強與漸進式偵測方法為前提，確保實驗設計與研究方法在資料格式與評估目標上一致。

4.2.1 SAGA (Synthetic Audit Log Generation for APT Campaigns) 資料集

在進階持續性威脅（APT）的偵測研究中，取得具備詳細 TTP 標記的真實攻擊日誌一直是相當大的困難。為了解決訓練資料稀缺與標記不全的問題，SAGA [26] 提出了一套合成系統稽核日誌的生成框架。該資料集結合 Caldera (Cyber Adversary Language and Decision Engine for Red Team Automation) [30] 與 MITRE ATT&CK [4] 框架，將惡意攻擊行為與正常系統背景操作融合以盡可能還原真實攻擊情境，其主要貢獻在於能夠彈性配置攻擊時長，並產出涵蓋已知攻擊組織（如 APT28、FIN7 等）與隨機生成的複雜攻擊場景。透過提供細緻顆粒度（fine-grained）的技術標籤，SAGA 可作為機器學習模型在溯源圖分析、威脅狩獵（technique hunting）及 APT 偵測任務上的基準測試資料（benchmark），一定程度彌補現有公開資料集在標記精確度與場景多樣性上的不足。基於此優勢，本研究的訓練與 campaign 級評估以 SAGA Known APT Campaigns [26] 攻擊場景資料夾作為戰役級測試資料的主要來源。

4.2.2 Kollect4APT 資料集

針對作業系統核心（kernel）層級的日誌蒐集，過往工具常面臨效能瓶頸與語意缺失的限制。Kollect4APT [8] 是一套藉由 Windows 事件追蹤機制（ETW，Event Tracing for Windows）開發的高效無損日誌蒐集工具 KELLECT，並建構於 Atomic Red Team 框架的上的 TTP 攻擊資料集，該資料集針對 MITRE ATT&CK [4] 框架中多樣化的戰術與技術（TTPs）進行了完整的攻擊模擬。作為針對 Windows 系統核心事件的公開測試集，Kollect4APT 不僅為未來基於異常偵測或圖神經網路分析的資安研究提供了具備 TTP 偵測的實證基礎，也是本研究第三章所述的事件三元組抽取邏輯與 3.4 節漸進式偵測管線的主要開發與驗證資料來源。

資料集背景雜訊過濾與特徵優化 KELLECT4APT [8] 資料集的原作者爲了還原真實攻擊的環境並有效訓練異常分類器，他們在樣本中注入大量背景雜訊，但並未提供該雜訊的具體來源與明確標籤。若直接將包含雜訊的原始資料輸入模型進行 TTP 偵測容易使模型受到不相關的良性事件干擾，導致特徵空間中的良性與異常邊界模糊不清。

爲解決這個資料干擾問題，本研究對該資料集進行人工統計與關聯分析，篩選出符合原作者描述、且與真實攻擊行爲無顯著關聯的良性雜訊行程 (processes)。具體而言，本研究識別出以下數個影音與附屬應用程式作爲主要的背景干擾源：huyaplayerModule.exe、HuyaExternal.exe、HuyaClient.exe 以及 HuyaApplet.exe。這個作法借鑑自 TREC [18] 與 ZOOMER [19] 的處理方式。爲避免這類節點誤導後續 TTP 偵測結果，於 TTP 偵測架構中將其忽略。

透過在資料前處理階段精準濾除上述良性雜訊，不僅能大幅降低無效上下文對模型注意力機制的干擾，也使生成的事件嵌入 (event embedding) 在特徵空間中更具代表性與鑑別度。此降噪策略有效引導模型聚焦於真實的惡意攻擊語意，進而顯著提升了後續 TTP 偵測任務的整體表現。

表 4-1: Statistics of Datasets

Dataset	SAGA	KELLECT4APT
Platform	Windows	Windows
Scenario	5	N/A
Host Count	1	1
Time Period	15 min / 1 hr / 1 day	N/A
Total Lines	7,237,684	48,987,382
Host Log (Process)	236,363	2,231,423
Host Log (Event)	3,117,797	48,987,382
(Benign)	3,088,312	-
(Malicious)	29,485	-

4.3 資料集切分方式

由於本研究涵蓋異常偵測與 TTP 偵測學習任務，且分別於 KELLECT4APT [8]、SAGA [26] 等不同資料來源進行訓練與驗證，本研究並未採用單一固定的資料切分規

則，而是依各任務的統計特性與評估目的分別設計對應的切分策略。

4.3.1 KELLECT4APT 切分

在 KELLECT4APT [8] TTP 偵測管線中，每個攻擊技術類別先以 MD5 雜湊演算法對類別名稱字串取得穩定亂數種子，確保切分結果不受類別掃描順序影響、可完全重現；接著固定保留每類別 1 筆樣本作爲推論集，此推論集僅用於模型訓練完成後的獨立驗證。其餘樣本再依驗證集與測試集各佔 20% 的比例切分爲訓練／驗證／測試集，只有訓練集享有最低樣本數保障：若扣除驗證與測試後訓練樣本數低於下限，系統會優先保障訓練集大小，再依比例重新分配驗證與測試樣本；若一個類別扣除持出樣本後的剩餘樣本數仍不足以支應此下限，該類別將被排除於本次訓練。此外，訓練集的滑動視窗保留全部重疊視窗以增加訓練資料量，驗證與測試集則以固定間隔進行不重疊抽樣，避免評估指標因高度重疊的相鄰視窗而錯誤提高。

在異常偵測架構中，資料集切分以 TTP 技術攻擊資料夾爲單位，各自獨立進行 80% 訓練／ 10% 驗證／ 10% 測試的隨機切分，而非全域單一次切分，藉此確保每個技術類別在三個子集合中皆有一定程度的代表性。One-Class SVM 僅以訓練集中的良性視窗進行自監督訓練，並且超參數於驗證集（須同時含良性與已標記異常樣本）上以 ROC-AUC 進行網格搜尋，測試集則全程保留至最終效能評估，未參與調整模型或超參數。

4.3.2 SAGA dataset 切分

在 SAGA 合成 campaign 級 TTP 標記器的訓練管線中，切分爲兩個層次：首先於 TTP 技術攻擊子資料夾層級，以固定種子對排序後的資料夾清單進行洗牌，依 80% 訓練／ 10% 驗證／約 10% 測試切分原始攻擊實例檔案；然而實際餵入模型的訓練與驗證視窗，並非直接取自這些原始實例，而是進一步以合成方式產生——訓練視窗以訓練集實例中的攻擊片段與大量良性事件混合、依目標非良性密度合成固定長度視窗，驗證視窗則改以「held-out ability」（驗證集所屬、訓練階段從未取用其攻擊片段的技術類別）的實例合成，並採更貼近實際部署情境的較低攻擊密度，藉此模擬模型於同技術、未見過的實例上的預測能力。此設計的核心精神在於全程不碰觸 SAGA campaign 的真實標籤，無論模型訓練或最終權重選擇，皆僅依賴上述合成的驗證集，確保後續於真實 campaign 資料上的效能評估具備充分的獨立性。

至於用於推論階段的 SAGA Known 資料集，則與上述訓練資料在來源層級完全

不重疊：其做法由 Caldera ability 清單中，挑選一組未曾出現於前述 16,900 個訓練用 ability 的獨立能力集合，並依 MITRE ATT&CK 攻擊鏈邏輯串接還原為具備完整敘事脈絡的真實 APT 攻擊場景，作為端到端 campaign 級評估的測試資料。此一訓練與推論資料來源徹底分離的設計使推論階段的效能評估得以真實反映模型面對未見過攻擊組合時、對完整攻擊敘事的還原與辨識能力，避免因訓練與測試資料重疊而高估模型的泛化表現。

4.4 異常偵測比較

本研究的漸進式偵測架構第一階段為異常偵測閘門 (3.4.1 節)，其目的在於以低成本方式快速濾除大量良性事件，僅將異常事件保留至後續 TTP 偵測階段。在本次實驗中，異常偵測階段的比較基準僅選用 SFM [31] 論文中所採用的 RBF 核單類別支持向量機 (RBF-OCSVM)，TREC [18] 與 ZOOMER [19] 兩篇文獻聚焦於少樣本 TTP 辨識任務，並未提供對應的異常濾除階段結果，故未納入本節比較範圍。本節的比較實驗於 SAGA dataset [26] 上進行，評估本研究第三章所述對比學習編碼器搭配異常偵測閘門的方法，相較於 SFM 的 RBF-OCSVM 基準，在 Precision、Recall 與 F1-Score 上的表現差異。

4.5 TTP 偵測比較

在本次實驗中，我們選用 SFM (Straight Forward Method) [31] 框架作為主要比較基準，TREC [18] 與 ZOOMER [19] 則作為於不同型態資料集的表現比較。SFM [31] 旨在透過分析系統日誌來識別進階持續性威脅 (APT) 活動，其系統架構涵蓋三個主要階段：首先利用預訓練語言模型 SecureBERT [32] 將資安日誌轉換為事件嵌入 (event embedding)；接著藉由單類別支持向量機 (One-Class SVM) 濾除正常事件後，輸入 BiGRU-CRF 模型進行事件序列特徵學習與攻擊模式識別；最後透過圖編輯距離 (graph edit distance) 演算法進行 APT 活動匹配 (APT campaign matching)。本研究第三章所述的結構化 528 維事件向量格式，設計為與 SFM [31] 相容，其技術層級偵測輸出平均 F1 為 68.64%，作為本研究後續實驗的主要基準。

由於本研究的核心在於精準辨識攻擊戰術、技術 (TTPs)，因此在後續的效能評估中，我們將擷取 SFM [31] 框架內的技術獵捕 (technique hunting) 模組作為主要對照組，並同時納入 TREC [18] 與 ZOOMER [19] 兩個以少樣本學習為核心的 TTP 辨識基準方法。透過將上述基準方法與本研究提出的漸進式偵測方法在 TTP 偵測任務上進行比

較，評估本方法在處理複雜主機日誌與提取攻擊特徵時的準確性與誤報率，並檢驗 LLM 語意特徵，以及多尺度前處理設計 (MultiChunk / MultiHop) 各自對最終效能的影響。



第五章 實驗結果與分析

本章依 4.2 與 4.3 之比較設計，呈現本研究之實驗結果，並與相關基準方法進行比較分析。

5.1 異常偵測結果與分析

本節呈現本研究第一階段異常偵測架構於 SAGA 資料集上之 Precision、Recall 與 F1-Score，並與 4.4 節所述之 SFM RBF-OCSVM 基準比較，藉此評估本研究採用之對比學習編碼器所產生之表徵，相較於傳統 One-Class SVM，在良性／異常事件分離上之效益。

在 One-Class SVM (OCSVM) 異常檢測模型中，參數 ν 扮演著控制模型決策邊界 (Decision Boundary) 嚴格程度的關鍵角色。根據 Schölkopf [33] 等人的定義， $\nu \in (0, 1]$ 具有嚴格的數學意義，該參數同時規範了訓練集內被允許判定為異常值 (Outliers) 的比例上限，以及作為支持向量 (Support Vectors) 的資料點比例下限。

表 5-1: Comparison of OneClassSVM (RBF) and OneClassSVM (Nystroem)

Model Architecture	Parameters	Precision	Recall	F1-Score
RBF OCSVM	$\nu = 0.02$	0.733	0.956	0.830
	$\nu = 0.04$	0.757	0.908	0.826
	$\nu = 0.06$	0.785	0.883	0.831
	$\nu = 0.08$	0.809	0.869	0.838
	$\nu = 0.10$	0.823	0.847	0.835
	$\nu = 0.12$	0.829	0.828	0.838
Nystroem + OCSVM	$\nu = 0.001$	0.842	0.959	0.897

在實驗過程中，調整 ν 值對最終的檢測成效產生了直接的權衡 (Trade-off) 影響。具體觀察如下：

- 當 ν 值較大時，模型被強制捨棄較多比例的正常訓練樣本，這在 Nyström 近似出的低維線性空間中，導致 SGD 優化器畫出的超平面 (Hyperplane) 過於偏移，反而將許多原本具備明確惡意特徵的樣本錯誤地劃歸至決策邊界內也就是將惡意誤判為正常，導致召回率衰退。
- 相反地，當設定極低的 ν 值 (如 0.001) 時，模型必須盡可能地包容所有良性訓練資料。由於本研究的事件特徵已具備一定的聚類特性，此「最大化包容良性資料」的目標，反而促使 SGD 優化器尋找到一個最具泛化能力的穩定邊界，成功將正常日誌的分佈緊密包覆，進而將結構截然不同的惡意 TTP 樣本有效阻擋在邊界之外，使得召回率大幅提升。

此一實證發現凸顯了在處理大規模且高維度的系統日誌時，特徵空間的穩定性往往比單純限縮決策邊界更為重要。

除了邊界參數的調校之外，在處理大規模的系統日誌與威脅狩獵資料時，標準核方法 (Kernel Methods) 的計算與記憶體複雜度 (通常為 $O(n^3)$ 與 $O(n^2)$ ，其中 n 為樣本數) 往往成為 OCSVM 訓練的顯著瓶頸。為了突破此限制並提升實驗效率，本研究使用 Nyström 方法來近似核函數的特徵映射。

透過 Nyström 近似技術，我們將原本高維度的非線性核矩陣映射轉換為低維度的線性特徵表示。在實驗驗證中，此方法的引入帶來了兩項關鍵優勢：

- **大幅節省訓練與推論時間：**Nyström 方法允許我們在近似後的特徵空間中使用線性求解器，將原本龐大的非線性運算轉化為線性時間複雜度。這使得模型在面對海量日誌數據時，訓練時間得以大幅縮減，滿足了實際應用中對效率的需求。
- **優化硬體成本：**該方法避免了在運算過程中建立並儲存全部的核矩陣，成功解決了傳統 OCSVM 難以擴展至大型資料集的硬體限制。實驗數據顯示，在引入 Nyström 近似後，模型在節省大量運算資源的同時，仍能維持一定的檢測精準度，確保了 F1-Score 的穩定性。

綜合以上所述，由於 APT 攻擊中的惡意行為在一個日誌裡面可能只占 1% 到 0.01%，因此本實驗將 ν 值設定為 **0.001** 並結合 Nyström 近似，不僅在精準度與召回率之間取得了最佳平衡，也同時確保了模型在處理 APT 攻擊日誌時的運算效率與實用性。

5.2 TTP 偵測結果與分析

本節呈現本研究所提之 TTP 偵測模型 (3.4.2 節) 在 KELLECT4APT [8]、SAGA [26] (SAGA Known dataset) 上的效能評估結果。透過 Precision、Recall 與 F1-Score 等量化指標，將本模型與 4.2 節所述之 SFM、TREC 及 ZOOMER 等基準方法進行綜合比較。後續之分析重點將涵蓋以下四項：

- (一) **基準效能比較**：探討本研究方法是否能超越 SFM [31] 論文中所達到的平均 $F1 = 68.64\%$ 之校準基準。
- (二) **特徵消融分析**：分析 LLM 語意特徵在使用與不使用時之效能差異。
- (三) **前處理策略評估**：比較 MultiChunk (時間序列) 與 MultiHop (溯源圖 k -hop) 兩種前處理策略的優劣。
- (四) **Hop 變體之架構分析**：針對實驗中表現較佳的 MultiHop 策略，進一步比較模型內部 Transformer 數量配置對效能的影響，探討每 Chunk 各投入一個 Transformer 與全域共用單一 Transformer 兩種架構設計之差異。

5.2.1 針對 KELLECT4APT 的分析

在 4.2.2 節中提到，KELLECT4APT [8] 在 TREC [18] 和 ZOOMER [19] 的作法是使用作者預先使用噪聲以及良性資料訓練好的向量空間做異常偵測以達到後續 TTP 偵測的效益最大化，然後在 KELLECT4APT [8] 釋出的公開資料中並沒有提供任何良性資料和噪聲來源，並且 KELLECT4APT 的審計日誌為一個 TTP 腳本的錄製成果為單位，與 SFM [31] 和本研究適用的 APT 攻擊具有截然不同的情境，所以在 KELLECT4APT [8] 的偵測任務上，本研究定義為 TTP 分類而非 TTP 偵測與威脅偵測。由於適用情境不同，其表現在 SFM [31] 和本研究的架構上皆差強人意。

表 5-2: TTP Detection Performance on KELLECT4APT

Method	Precision	Recall	F1-Score
TREC	0.8850	0.8920	0.8885
Zoomer	0.7550	0.9120	0.8340
SFM	0.1482	0.1079	0.1249
Transformer (Temporal)	0.2436	0.3846	0.2863
Transformer (Hop)	0.2671	0.4103	0.3094

表 5-3: Evaluation Results of TTP Detection without LLM embedding

APT Campaign	P					R					F1				
	Sigma	SFM	Transformer (Temporal)	Transformer (hop)		Sigma	SFM	Transformer (w/o LLM, Multichunk)	Transformer (Temporal)	Transformer (hop)	Sigma	SFM	Transformer (w/o LLM, Multichunk)	Transformer (Temporal)	Transformer (hop)
Higaisa	33.37%	90.32%	92.98%	35.37%	61.48%	36.11%	90.48%	92.86%	44.05%	84.52%	33.40%	87.00%	92.01%	34.05%	64.03%
APT28	0.00%	56.30%	60.86%	40.53%	51.81%	0.00%	62.45%	52.27%	45.63%	44.23%	0.00%	57.02%	54.51%	39.76%	45.65%
CobaltGroup	0.28%	54.82%	71.69%	42.11%	70.72%	29.75%	72.31%	71.48%	72.70%	72.23%	0.54%	58.44%	71.58%	47.52%	71.45%
Gamaredon	25.02%	73.51%	81.46%	53.66%	86.94%	17.08%	77.75%	74.44%	68.54%	65.93%	16.71%	73.21%	76.51%	51.23%	67.90%
Patchwork	8.13%	68.60%	50.70%	34.39%	65.93%	21.96%	68.87%	60.24%	49.21%	63.09%	9.14%	67.55%	50.74%	35.53%	58.93%
Avg.	13.36%	68.71%	71.54%	41.21%	67.38%	20.98%	74.37%	70.26%	56.03%	66.00%	11.96%	68.64%	69.07%	41.62%	61.59%

表 5-4: Evaluation Results of TTP detection with and w/o LLM embedding

APT Campaign	P				R				F1			
	Sigma	SFM	Transformer (hop)	Transformer (hop+Qwen)	Sigma	SFM	Transformer (hop)	Transformer (hop+Qwen)	Sigma	SFM	Transformer (hop)	Transformer (hop+Qwen)
Higaisa	33.37%	90.32%	61.48%	28.57%	36.11%	90.48%	84.52%	28.57%	33.40%	87.00%	64.03%	28.57%
APT28	0.00%	56.30%	51.81%	30.12%	0.00%	62.45%	44.23%	33.33%	0.00%	57.02%	45.65%	31.56%
CobaltGroup	0.28%	54.82%	70.72%	35.96%	29.75%	72.31%	72.23%	30.63%	0.54%	58.44%	71.45%	32.46%
Gamaredon	25.02%	73.51%	86.94%	16.67%	17.08%	77.75%	65.93%	11.64%	16.71%	73.21%	67.90%	12.08%
Patchwork	8.13%	68.60%	65.93%	10.95%	21.96%	68.87%	63.09%	11.11%	9.14%	67.55%	58.93%	11.03%
Avg.	13.36%	68.71%	67.38%	24.45%	20.98%	74.37%	66.00%	23.06%	11.96%	68.64%	61.59%	23.14%

表 5-5: Evaluation Results of TTP detection with different multi-chunk method

APT Campaign	P				R				F1			
	Sigma	SFM	Transformer (hop)	Transformer (hop*3)	Sigma	SFM	Transformer (hop)	Transformer (hop*3)	Sigma	SFM	Transformer (hop)	Transformer (hop*3)
Higaisa	33.37%	90.32%	61.48%	10.71%	36.11%	90.48%	84.52%	14.29%	33.40%	87.00%	64.03%	12.24%
APT28	0.00%	56.30%	51.81%	15.42%	0.00%	62.45%	44.23%	16.66%	0.00%	57.02%	45.65%	16.02%
CobaltGroup	0.28%	54.82%	70.72%	56.17%	29.75%	72.31%	72.23%	63.83%	0.54%	58.44%	71.45%	55.30%
Gamaredon	25.02%	73.51%	86.94%	2.78%	17.08%	77.75%	65.93%	3.70%	16.71%	73.21%	67.90%	3.17%
Patchwork	8.13%	68.60%	65.93%	23.47%	21.96%	68.87%	63.09%	25.30%	9.14%	67.55%	58.93%	24.20%
Avg.	13.36%	68.71%	67.38%	21.71%	20.98%	74.37%	66.00%	24.76%	11.96%	68.64%	61.59%	22.19%

第六章 結論與後續工作

6.1 結論

本研究提出並實作了一套漸進式的威脅偵測架構，旨在解決傳統基於系統日誌的入侵偵測系統中，誤報率過高且缺乏攻擊上下文的問題。透過實驗設計與對照分析，本研究不僅驗證了系統的實用性，更獲得了以下幾項結論：

- **異常偵測作為有效的前置處理：**透過第一階段的篩選機制，系統成功過濾絕大多數的常規合法操作。這不僅大幅降低了後續 TTP 偵測模組的運算負擔，也有效縮減了誤報發生的空間。
- **純 Transformer 架構表現較佳：**這是本研究最關鍵的發現。原先預期導入 LLM 的 Embedding 能為底層日誌提供更豐富的高階語意，但實驗數據明確指出，疊加 LLM 特徵反而對模型表現造成了負面影響。相對地，單純使用純 Transformer 架構來學習日誌本身的結構化與序列特徵反而取得了最佳且最穩定的整體表現。這證實了在處理底層系統日誌時，特徵空間的乾淨程度與結構性，遠比外部引入的複雜語意更為重要。
- **前處理策略的局限與圖結構的潛力：**在日誌上下文的建構中，本研究比較了基於時間序列的 Multi-chunk 與基於溯源圖的 Multi-hop 策略。結果顯示，雖然 Multi-hop 在整體評估中略佔優勢，但進一步的細部探討發現，其效能領先主要集中在特定的推論子集中，並未全面超越 Transformer 架構。這意味著圖結構確實能捕捉到特定型態的隱蔽關聯，但在通用性上仍有最佳化的空間。

總結來說，本研究最大的貢獻不僅是建構了一套能減輕資安人員負擔的自動化威脅偵測系統，更透過消融實驗釐清了 LLM 與圖結構在系統日誌分析中的限制。實驗結果證明，在目前的溯源圖與日誌分析領域中，輕量化且專注於序列結構的純 Transformer 架構，在效能與精準的考量下是相對的最佳解。

6.2 後續工作與未來展望

基於本研究的實證結果與現有架構的限制，針對未來在威脅偵測領域的作法提出以下幾項建議與展望：

1. LLM 在日誌分析中的重新定位：

鑑於本研究發現直接提取 LLM Embedding 會干擾模型特徵空間，未來的研究應重新評估 LLM 在此領域的應用方式。例如，可放棄將 LLM 作為前端的特徵萃取器，改為部署於偵測管線的最末端，作為威脅解釋器來生成易讀的資安報告，以及提供解決方法或是探討針對資安日誌進行深度微調 (Fine-tuning) 的專屬小型語言模型。

2. 圖結構特徵與跨主機關聯：

雖然 Multi-hop 策略目前僅在特定推論子集中展現優勢，但這也暗示了圖結構在面對特定進階攻擊時的潛力。未來的研究可嘗試借鏡 TREC [18] 導入圖神經網路 (GNN) 來強化節點間的訊息傳遞，取代現有單純 2 的特徵截取。此外，也可將範圍由單一主機擴展至跨主機的網路流量關聯，以更全面地還原 APT 攻擊的橫向移動 (Lateral Movement) 軌跡。

3. 提升面對零日攻擊 (Zero-day Attacks) 的泛化能力：

現有系統的 TTP 偵測仍較為依賴 MITRE ATT&CK 框架中既有的攻擊模式。未來可探索連續學習 (Continual Learning) 或少樣本學習 (Few-shot Learning) 機制，使系統在面對攻擊者使用未知的攻擊技術時，依然能保持威脅狩獵的能力。

4. 整合自動化協調與應變系統 (SOAR)：

為使研究成果更貼近真實世界，未來可將本架構的輸出結果與資安協調、自動化與回應 (SOAR) 平台對接。透過 API 實現從精準偵測、自動隔離到提供動態防禦規則建議的自動化流程，進一步降低資安維運成本。

参 考 文 献

- [1] E. Aghaei, S. Jain, P. Arun, and A. Sambamoorthy, “Securebert 2.0: Advanced language model for cybersecurity,” *arXiv*, 2025.
- [2] W. Qiao, Y. Feng, Z. Ma, Y. Shen, and Y. Liu, “SLOT: Provenance-driven apt detection through graph reinforcement learning,” *arXiv preprint arXiv:2410.17910*, 2024.
- [3] Z. Cheng, Q. Lv, J. Liang, Y. Wang, D. Sun, T. Pasquier, and X. Han, “KAIROS: Practical intrusion detection and investigation using whole-system provenance,” in *2024 IEEE Symposium on Security and Privacy (SP)*, 2024.
- [4] MITRE, “MITRE ATT&CK.” <https://attack.mitre.org/>, 2025. Accessed: 2026-07-16.
- [5] M. Zipperle, F. Gottwalt, E. Chang, and T. Dillon, “Provenance-based intrusion detection systems: A survey,” *ACM Computing Surveys (CSUR)*, vol. 55, no. 7, pp. 1–36, 2022.
- [6] Z. Li, Q. A. Chen, R. Yang, Y. Chen, and W. Ruan, “Threat detection and investigation with system-level provenance graphs: A survey,” *arXiv preprint arXiv:2006.01722*, 2020.
- [7] T. Pasquier, X. Han, M. Goldstein, T. Moyer, D. Eysers, M. Seltzer, and J. Bacon, “Practical whole-system provenance capture,” in *Proceedings of the 2017 ACM Symposium on Cloud Computing (SoCC '17)*, pp. 405–418, Association for Computing Machinery, 2017.
- [8] T. Chen, Q. Song, T. Zhu, X. Qiu, Z. Zhu, and M. Lv, “KELLECT: A kernel-based efficient and lossless event log collector.” <https://www.kellect.org/#/>, 2024. Accessed: 2026-07-16.

- [9] M. N. Hossain, S. M. Milajerdi, J. Wang, B. Eshete, R. Gjomemo, R. Sekar, S. D. Stoller, and V. N. Venkatakrishnan, “SLEUTH: Real-time attack scenario reconstruction from cots audit data,” in *Proceedings of the 26th USENIX Security Symposium (USENIX Security 17)*, 2017.
- [10] S. M. Milajerdi, R. Gjomemo, B. Eshete, R. Sekar, and V. N. Venkatakrishnan, “HOLMES: Real-time apt detection through correlation of suspicious information flows,” in *2019 IEEE Symposium on Security and Privacy (SP)*, 2019.
- [11] S. M. Milajerdi, R. Gjomemo, B. Eshete, R. Sekar, and V. N. Venkatakrishnan, “POIROT: Aligning attack behavior with kernel audit records for cyber threat hunting,” in *Proceedings of the 2019 ACM SIGSAC Conference on Computer and Communications Security (CCS)*, 2019.
- [12] E. Manzoor, S. M. Milajerdi, and L. Akoglu, “Fast memory-efficient anomaly detection in streaming heterogeneous graphs,” in *Proceedings of the 22nd ACM SIGKDD International Conference on Knowledge Discovery and Data Mining (KDD)*, 2016.
- [13] X. Han, T. Pasquier, A. Bates, J. Mickens, and M. Seltzer, “UNICORN: Runtime provenance-based detector for advanced persistent threats,” in *Proceedings of the 27th Annual Network and Distributed System Security Symposium (NDSS)*, 2020.
- [14] S. Wang, Z. Wang, T. Zhou, H. Sun, X. Yin, D. Han, H. Zhang, X. Shi, and J. Yang, “THREATTRACE: Detecting and tracing host-based threats in node level through provenance graph learning,” *IEEE Transactions on Information Forensics and Security*, vol. 17, 2022.
- [15] M. U. Rehman, H. Ahmadi, and W. U. Hassan, “FLASH: A comprehensive approach to intrusion detection via provenance graph representation learning,” in *2024 IEEE Symposium on Security and Privacy (SP)*, 2024.
- [16] Z. Jia, Y. Xiong, Y. Nan, Y. Zhang, J. Zhao, and M. Wen, “MAGIC: Detecting advanced persistent threats via masked graph representation learning,” in *Proceedings of the 33rd USENIX Security Symposium (USENIX Security 24)*, 2024.
- [17] H. Ding, J. Zhai, Y. Nan, and S. Ma, “AIRTAG: Towards automated attack investigation by unsupervised learning with log texts,” in *Proceedings of the 32nd USENIX Security Symposium (USENIX Security 23)*, 2023.

- [18] M. Lv, H. Gao, X. Qiu, T. Chen, T. Zhu, and J. Chen, "TREC: Apt tactic / technique recognition via few-shot provenance subgraph learning," in *Proceedings of the 2024 ACM SIGSAC Conference on Computer and Communications Security (CCS)*, 2024.
- [19] X. Qiu, M. Lv, T. Chen, T. Zhu, Q. Song, and Z. Zhu, "ZOOMER: An apt ttp recognition system via deep & wide provenance graph learning," *IEEE Transactions on Dependable and Secure Computing*, 2025.
- [20] F. Liu, Y. Wen, D. Zhang, X. Jiang, X. Xing, and D. Meng, "Log2vec: A heterogeneous graph embedding based approach for detecting cyber threats within enterprise," in *Proceedings of the 2019 ACM SIGSAC Conference on Computer and Communications Security (CCS)*, 2019.
- [21] H. Guo, S. Yuan, and X. Wu, "LogBERT: Log anomaly detection via bert," in *2021 International Joint Conference on Neural Networks (IJCNN)*, 2021.
- [22] S.-Y. Huang *et al.*, "CmdCaliper: A semantic-aware command-line embedding model and dataset for security research," in *Proceedings of the 2024 Conference on Empirical Methods in Natural Language Processing (EMNLP)*, 2024.
- [23] Z. Li, X. Zhang, Y. Zhang, D. Long, P. Xie, and M. Zhang, "Towards general text embeddings with multi-stage contrastive learning," *arXiv preprint arXiv:2308.03281*, 2023.
- [24] Gemini Team and Google DeepMind, "Gemini: A family of highly capable multi-modal models," *arXiv preprint arXiv:2312.11805*, 2023.
- [25] OpenAI, "Gpt-3.5 turbo." <https://platform.openai.com/docs/models>, 2023. Accessed: 2026-07-23.
- [26] Y.-T. Huang, Y.-R. Guo, Y.-S. Yang, G.-W. Wong, Y.-Z. Jheng, Y. Sun, J. Modini, T. Lynar, and M. C. Chen, "SAGA: Synthetic audit log generation for APT campaigns." <https://saga-tw.github.io/dataset/>, 2024. Accessed: 2026-07-16.
- [27] Qwen Team, "Qwen2.5: A party of foundation models." <https://qwenlm.github.io/blog/qwen2.5/>, 2024. Accessed: 2026-07-21.
- [28] AI@Meta, "The llama 3 herd of models," *arXiv preprint arXiv:2407.21783*, 2024.

- [29] A. Q. Jiang, A. Sablayrolles, A. Mensch, *et al.*, “Mistral 7b,” *arXiv preprint arXiv:2310.06825*, 2023.
- [30] MITRE Corporation, “Mitre caldera: Automated adversary emulation platform.” <https://github.com/apache/caldera>, 2025. Accessed: 2026-07-22.
- [31] Y.-T. Huang, Y.-R. Guo, G.-W. Wong, and M. C. Chen, “A cascade approach for apt campaign attribution in system event logs: Technique hunting and subgraph matching,” in *2024 IEEE International Conference on Communications (ICC)*, 2024.
- [32] E. Aghaei, X. Niu, W. Shadid, and E. Al-Shaer, “Securebert: A domain-specific language model for cybersecurity,” *arXiv preprint arXiv:2204.02685*, 2022.
- [33] B. Schölkopf, J. C. Platt, J. Shawe-Taylor, A. J. Smola, and R. C. Williamson, “Estimating the support of a high-dimensional distribution,” *Neural computation*, vol. 13, no. 7, pp. 1443–1471, 2001.



